ADscan | CLIENT DELIVERABLE KIT

ACTIVE DIRECTORY HARDENING PLAYBOOK

Your *30-day* path from findings to a hardened domain.

Built from the 23 findings ADscan confirmed against north.sevenkingdoms.local, sequenced into shippable work and mapped to the compliance controls each one closes.

FINDINGS	CRITICAL / HIGH	REMEDIATION WINDOW	FRAMEWORKS MAPPED
23	11	30 days	6

PREPARED

Confidential

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

November 10, 2026
Scope: north.sevenkingdoms.local

prepared for the named engagement

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

Where your domain is *exposed*, and what to ship first.

100% of standard user accounts (8 of 8) hold a reachable path to full domain compromise. 7 reachable route(s) to full domain compromise.

This engagement against north.sevenkingdoms.local surfaced 23 confirmed findings, 3 of which sit on a validated path to full domain compromise. The remaining findings widen the attack surface without, on their own, completing that path.

The highest-confidence fix, proven in this environment, is Service Account Credential Theft (Kerberoasting) on sql_svc, jon.snow (finding F-005, Kerberoasting, ADscan Priority 8): it breaks the most validated attack paths ADscan walked against your domain. Close it first; the remaining findings follow on the 30-day roadmap below, in this same remediation order.

These findings map to 73 distinct controls across ISO 27001:2022, DORA, ENS, NIS2, PCI DSS 4.0, CIS Windows Server. The compliance-gap summary on this page lists the exact control codes each finding leaves open, so the roadmap doubles as an audit-remediation register.



CRITICAL · 2 (9%) HIGH · 9 (39%) MEDIUM · 11 (48%) LOW · 1 (4%)

CONFIRMED FINDINGS

23

surfaced in this engagement, de-duplicated across scope.

FINDINGS ON A VALIDATED PATH

3

findings whose technique sits on a path to full domain compromise, confirmed by configuration. Routes where only the entry step is proven and the chain is not walked end to end (partially validated) are detailed in the Security Assessment Report.

TOP EXPOSURE

Service Account Credential Theft (Kerberoasting)

F-005 · ADscan Priority 8 · close it first.

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

How to close each finding, *in remediation order*.

Each runbook is keyed to the finding ID in your Security Assessment Report. The report says what is wrong and how bad; this is the step-by-step fix, the exact commands, and how to prove it landed. ***The runbook number is the remediation order****, and runbook 01 is the single fix that reduces your exposure most. The first 3 runbooks lead because they break a validated attack path, each flagged* ***Path-breaker N of 3****, and the rest follow by severity. The ADscan Priority score beside each finding measures its severity; it is not the order. The first fix is* ***Service Account Credential Theft (Kerberoasting)*** *(finding F-005); close it first. Those validated routes are what put 8 of 8 of your standard user accounts (100%) within reach of full domain compromise, so the path-breaker runbooks are where that exposure drops.*

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

01 Kerberoasting

PATH-BREAKER 1 OF 3 · F-005 · HIGH · Priority 8 · KERBEROS · T1558.003

These 3 path-breaker fixes sit on the validated routes that put 8 of 8 of your standard user accounts (100%) within reach of full domain compromise. This one breaks an entry step on the largest share of them, which is why it leads.

AFFECTED

WHAT IT EXPOSES

- TIER 1 sql_svc EXPOSED *roastable-target*
- TIER 2 jon.snow EXPOSED *roastable-target*
- TIER 2 sansa.stark EXPOSED *roastable-target*

DETAIL

- Request scope: any member of Authenticated Users can request a Kerberos service ticket for these accounts and crack it offline to recover the password.

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

PRIMARY Migrate the SPN to a Group Managed Service Account (gMSA)

STEPS

1. Confirm the Key Distribution Service root key exists in the forest (create it once if absent; it becomes effective after 10 hours of AD replication).
2. Create a gMSA and authorise the hosts that run the service to retrieve its managed password.
3. Install the gMSA on each service host and reconfigure the service to log on as the gMSA (NORTH\gmsa$, no password).
4. Move the SPN to the gMSA and disable / remove the old user-based service account.

COMMANDS

Create the Key Distribution Service root key, once per forest, if it does not exist yet. It becomes usable about 10 hours later, once it has replicated.

PowerShell

```
Add-KdsRootKey
```

Create the gMSA for the service and allow the host that runs it to retrieve its password.

PowerShell

```
New-ADServiceAccount -Name <new_gmsa_name> -DNSHostName
<new_gmsa_name>.north.sevenkingdoms.local -PrincipalsAllowedToRetrieveManagedPassword
'<service_host>$'
```

Fill in `<new_gmsa_name>` and `<service_host>` before running it.

On the service host, install the gMSA, then set the service to log on as it.

PowerShell

```
Install-ADServiceAccount -Identity <new_gmsa_name>
```

Fill in `<new_gmsa_name>` before running it.

Once the service runs as the gMSA, move the SPN: remove it from the old account, then register it on the gMSA. Domain controllers refuse a duplicate SPN, so the order matters.

PowerShell

```
Set-ADUser jon.snow -ServicePrincipalNames @{Remove='<service_principal_name>'}
Set-ADServiceAccount <new_gmsa_name> -ServicePrincipalNames @{Add='<service_principal_name>'}
```

Shown for jon.snow. Run it for each of the 3 affected accounts, with that account's own values. The full list is under Affected Assets.

Fill in `<service_principal_name>` and `<new_gmsa_name>` before running it.

CONFIRM THE FIX

> Test-ADServiceAccount returns True on the service host, and setspn lists the SPN under the gMSA rather than the old user account.

On the service host, this returns True once the gMSA is installed.

PowerShell

```
Test-ADServiceAccount -Identity <new_gmsa_name>
```

Fill in `<new_gmsa_name>` before running it.

The SPN now belongs to the gMSA.

PowerShell

```
setspn -L NORTH\<new_gmsa_name>$
```

Fill in `<new_gmsa_name>` before running it.

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

FALLBACK Harden the service account in place (AES + long password)

When: If the service cannot run as a gMSA (third-party app, clustered/cross-host service, or vendor support constraints)

STEPS

1. Set a random 25+ character password on the service account and establish a periodic rotation schedule.
2. Restrict the account to AES encryption types so any roasted ticket is AES (orders of magnitude slower to crack than RC4).
3. Remove the account from privileged groups; grant only the rights the service actually needs.
4. Where supported, mark the account 'Account is sensitive and cannot be delegated'.

COMMANDS

Restrict the account to AES. The value 24 allows AES128 and AES256 and nothing else.

PowerShell

```
foreach ($account in 'jon.snow', 'sansa.stark', 'sql_svc') { Set-ADUser $account -Replace
@{'msDS-SupportedEncryptionTypes'=24} }
```

Run this once. It covers all 3 affected accounts.

Set a long random password. The reset also creates the AES keys the new encryption types need. Record the password in your vault before the service restarts.

PowerShell

```
foreach ($account in 'jon.snow', 'sansa.stark', 'sql_svc') {
    $pw = [System.Web.Security.Membership]::GeneratePassword(28,6)
    Set-ADAccountPassword $account -Reset -NewPassword (ConvertTo-SecureString $pw -
AsPlainText -Force)
}
```

Run this once. It covers all 3 affected accounts.

Mark the account as sensitive so it cannot be delegated.

PowerShell

```
foreach ($account in 'jon.snow', 'sansa.stark', 'sql_svc') { Set-ADAccountControl $account -
AccountNotDelegated $true }
```

Run this once. It covers all 3 affected accounts.

CONFIRM THE FIX

> The account's encryption types read 24 and its password was set today. A service ticket requested for it in a controlled test is AES256 ($krb5tgs$18$), not RC4 ($krb5tgs23).

The encryption types read 24 and PasswordLastSet shows today's date.

PowerShell

```
foreach ($account in 'jon.snow', 'sansa.stark', 'sql_svc') { Get-ADUser $account -Properties
msDS-SupportedEncryptionTypes,PasswordLastSet | Format-List Name,msDS-
SupportedEncryptionTypes,PasswordLastSet }
```

Run this once. It covers all 3 affected accounts.

CLOSES

ISO 27001:2022 `A.8.2` `A.5.17` `A.8.5` DORA `Art. 6` `Art. 9(4)(d)` ENS `op.acc.5` `op.acc.4`
NIS2 `Art. 21(2)(h)` `Art. 21(2)(j)` PCI DSS 4.0 `Req. 8` `Req. 11`
CIS WINDOWS SERVER `2.3.11.4` `1.1.4`

REFS

- https://attack.mitre.org/techniques/T1558/003/
- https://learn.microsoft.com/en-us/windows-server/security/kerberos/kerberos-authentication-overview
- https://learn.microsoft.com/en-us/azure/architecture/guide/technology-choices/adfs

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

02 Constrained Kerberos Delegation Misconfiguration

PATH-BREAKER 2 OF 3 · F-003 · HIGH · Priority 8.5 · DELEGATION · T1558

AFFECTED

WHO CAN EXPLOIT IT

TIER 1 castelblack.north.sevenkingdoms.local (192.168.180.22) *delegating-account*

TIER 2 jon.snow *delegating-account*

WHAT IT EXPOSES

TIER 0 winterfell.north.sevenkingdoms.local (192.168.180.11) *target-service*

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

PRIMARY

Tighten msDS-AllowedToDelegateTo and drop unneeded protocol transition

STEPS

1. Read msDS-AllowedToDelegateTo on the delegating account and review every target SPN it is allowed to reach.
2. Remove any delegation to sensitive services, particularly CIFS, HOST, LDAP, or HTTP on Domain Controllers and Tier-0 systems, and trim the list to the minimum the application genuinely requires.
3. If the account has TrustedToAuthForDelegation (protocol transition / 'Use any authentication protocol'), remove it unless S4U2Self is strictly required, leaving only constrained delegation with 'Kerberos only'.
4. Add the high-value users that must never be impersonated to Protected Users or mark them non-delegatable.

COMMANDS

Read the allowed targets and the UAC delegation flags (the delegating account is often a computer, so resolve it object-class-agnostically).

PowerShell

```
foreach ($trustee in 'castelblack$', 'jon.snow') { Get-ADObject -LDAPFilter "
(sAMAccountName=${trustee})" -Properties msDS-
AllowedToDelegateTo,TrustedToAuthForDelegation,userAccountControl }
```

Run this once. It covers both affected principals holding the right.

Replace the allowed-target list with the minimal scoped set.

PowerShell

```
Get-ADObject -LDAPFilter '(sAMAccountName=castelblack$)' | Set-ADObject -Replace @{'msDS-
AllowedToDelegateTo'=@('HTTP/<approved-target-host>')}
```

Shown for castelblack$. Run it for each of the 2 affected principals holding the right, with that principal holding the right's own values. The full list is under Affected Assets.

Fill in `<approved-target-host>` before running it.

Drop protocol transition (clears TRUSTED_TO_AUTH_FOR_DELEGATION).

PowerShell

```
foreach ($trustee in 'castelblack$', 'jon.snow') { Set-ADAccountControl -Identity $trustee -
TrustedToAuthForDelegation $false }
```

Run this once. It covers both affected principals holding the right.

Protect a sensitive target user.

PowerShell

```
Set-ADUser <sensitive_account> -AccountNotDelegated $true; Add-ADGroupMember 'Protected Users'
-Members <sensitive_account>
```

Fill in `<sensitive_account>` before running it.

CONFIRM THE FIX

> Delegation is limited to the approved SPNs without protocol transition, an S4U request to a removed or domain controller service fails, and a new ADscan scan no longer reports the over-broad delegation.

msDS-AllowedToDelegateTo lists only the approved SPNs and TrustedToAuthForDelegation reads False.

PowerShell

```
foreach ($trustee in 'castelblack$', 'jon.snow') { Get-ADObject -LDAPFilter "
(sAMAccountName=${trustee})" -Properties msDS-AllowedToDelegateTo,TrustedToAuthForDelegation |
Format-List Name,msDS-AllowedToDelegateTo,TrustedToAuthForDelegation }
```

Run this once. It covers both affected principals holding the right.

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

FALLBACK

Migrate to resource-based constrained delegation (RBCD) or remove delegation entirely

When: If the delegation scope cannot be safely trimmed on the account side, or ownership of the targets is unclear

STEPS

1. Where the front-end service still needs delegation, move control to the RESOURCE side: clear msDS-AllowedToDelegateTo on the front-end and instead set msDS-AllowedToActOnBehalfOfOtherIdentity on each specific target computer, so the target owner governs who may impersonate to it.
2. Where no current process depends on the delegation, remove it entirely (clear the attribute and the UAC flags).
3. Re-test the application path after the change and monitor delegation-attribute edits.

COMMANDS

Clear classic constrained delegation on the front-end (object-class-agnostic, since the front-end account may be a computer).

PowerShell

```
foreach ($trustee in 'castelblack$', 'jon.snow') {
    Get-ADObject -LDAPFilter "(sAMAccountName=${trustee})" | Set-ADObject -Clear msDS-
AllowedToDelegateTo
    Set-ADAccountControl -Identity $trustee -TrustedToAuthForDelegation $false
}
```

Run this once. It covers both affected principals holding the right.

Grant RBCD on the specific target instead.

PowerShell

```
Set-ADComputer <target_computer> -PrincipalsAllowedToDelegateToAccount 'castelblack$'
```

Shown for castelblack$. Run it for each of the 2 affected principals holding the right, with that principal holding the right's own values. The full list is under Affected Assets.

Fill in `<target_computer>` before running it.

CONFIRM THE FIX

> msDS-AllowedToDelegateTo is empty on the front-end; if RBCD was used, the target computer's PrincipalsAllowedToDelegateToAccount lists only the approved front-end. The application still functions end-to-end.

CLOSES

ISO 27001:2022 `A.5.18` DORA `Art. 9(2)` ENS `op.acc.4` NIS2 `Art. 21(2)(i)`

PCI DSS 4.0 `Req. 7` `Req. 8` CIS WINDOWS SERVER `2.2.28`

REFS

- https://attack.mitre.org/techniques/T1558/
- https://learn.microsoft.com/en-us/windows-server/security/kerberos/kerberos-constrained-delegation-overview

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

03 AS-REP Roasting

PATH-BREAKER 3 OF 3 · F-017 · MEDIUM · Priority 4 · KERBEROS · T1558.004

AFFECTED

WHAT IT EXPOSES

TIER 2 `brandon.stark` EXPOSED *asrep-roastable-target*

DETAIL

- Request scope: any member of Authenticated Users can request an AS-REP for these accounts and crack it offline to recover the password.

RUNBOOK

PRIMARY

Re-enable Kerberos pre-authentication on affected accounts

STEPS

1. Enumerate every account with pre-authentication disabled (DONT_REQ_PREAUTH, bit 0x400000 in userAccountControl).
2. For each, confirm with the application owner that pre-auth was not required for a genuine legacy reason.
3. Clear the 'Do not require Kerberos preauthentication' flag.

COMMANDS

Find accounts with pre-auth disabled.

PowerShell

```
Get-ADUser -Filter 'useraccountcontrol -band 4194304' -Properties userAccountControl
```

Require pre-authentication again on the affected account.

PowerShell

```
Set-ADAccountControl -Identity brandon.stark -DoesNotRequirePreAuth $false
```

CONFIRM THE FIX

> DoesNotRequirePreAuth reads False on the account, and an AS-REP request without pre-authentication now fails with KDC_ERR_PREAUTH_REQUIRED.

Returns False once pre-authentication is required again.

PowerShell

```
Get-ADUser brandon.stark -Properties DoesNotRequirePreAuth | Select-Object
Name,DoesNotRequirePreAuth
```


SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

FALLBACK

Harden the account when pre-auth must stay disabled

When: If a legacy application or appliance genuinely requires pre-authentication to remain disabled

STEPS

1. Set a long random password (25+ chars) so any AS-REP hash is infeasible to crack offline.
2. Restrict the account to AES encryption types so the AS-REP is AES, not RC4.
3. Strip the account of any privileged group membership and scope its rights to the minimum.
4. Add the account to a Fine-Grained Password Policy enforcing a long minimum length and frequent rotation.

COMMANDS

PowerShell

```
$pw = [System.Web.Security.Membership]::GeneratePassword(28,6)
Set-ADAccountPassword brandon.stark -Reset -NewPassword (ConvertTo-SecureString $pw -
AsPlainText -Force)
```

AES-only (24 = AES128 + AES256).

PowerShell

```
Set-ADUser brandon.stark -Replace @{'msDS-SupportedEncryptionTypes'=24}
```

CONFIRM THE FIX

> The account's encryption types read 24, and an AS-REP requested for it in a controlled test is AES ($krb5asrep$18$), not RC4 ($krb5asrep23).

The encryption types read 24 and PasswordLastSet shows today's date.

PowerShell

```
Get-ADUser brandon.stark -Properties msDS-SupportedEncryptionTypes,PasswordLastSet | Format-
List Name,msDS-SupportedEncryptionTypes,PasswordLastSet
```

CLOSES

ISO 27001:2022 `A.5.17` `A.8.5` DORA `Art. 6` `Art. 9(4)(d)` ENS `op.acc.5`

NIS2 `Art. 21(2)(h)` `Art. 21(2)(j)` PCI DSS 4.0 `Req. 8` `Req. 11`

CIS WINDOWS SERVER `2.3.11.4` `1.1.4`

REFS

- https://attack.mitre.org/techniques/T1558/004/
- https://learn.microsoft.com/en-us/defender-for-identity/cas-isp-unsecure-account-attributes

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

04 Privileged Sessions on Lower-Tier Hosts

F-001 · CRITICAL · Priority 9.5 · PRIVILEGE · T1078.002

AFFECTED

TIER 0 robb.stark signed in to TIER 1 castelblack.north.sevenkingdoms.local (192.168.180.22)

RUNBOOK

PRIMARY Enforce tier separation with Deny-logon rights, Protected Users and Authentication Policy Silos

STEPS

1. Deny the higher-tier groups the logon rights that created each exposed session on the lower-tier hosts (the 'Deny log on' user rights on the affected servers and workstations).
2. Add the exposed Tier 0 accounts to the Protected Users group so their credentials are not cached and cannot be delegated on the hosts they touch.
3. Bind privileged accounts to Authentication Policy Silos so a higher-tier account can only obtain a Kerberos TGT from hosts of its own tier.
4. Require Privileged Access Workstations for all Tier 0 activity.

COMMANDS

Add the exposed privileged accounts to Protected Users (blocks NTLM, RC4, delegation, cred caching).

PowerShell

```
Add-ADGroupMember 'Protected Users' -Members robb.stark
```

GPO Deny rights on the lower-tier hosts (User Rights Assignment), for the higher-tier group. 'Deny log on locally' / 'Deny log on through Remote Desktop Services' / 'Deny access to this computer from the network' = <higher_tier_group>.

CONFIRM THE FIX

> A higher-tier logon attempt on a lower-tier host is denied by the user-rights policy; a review-only session hunt finds no higher-tier tokens on lower-tier hosts.

FALLBACK Use dedicated tier accounts and jump hosts where Protected Users breaks a workflow

When: If a privileged account must occasionally run a tool that Protected Users restrictions block

STEPS

1. Issue separate per-tier admin accounts distinct from daily-use identities, and keep daily accounts out of privileged groups.
2. Route all privileged access through a hardened, tier-matched jump host so credentials never land on a lower-tier endpoint.
3. Audit logons for privileged accounts on lower-tier hosts and alert on any non-compliant logon.

COMMANDS

Alert on a higher-tier logon to a lower-tier host (Event ID 4624 with a privileged account).

PowerShell

```
Get-WinEvent -FilterHashtable @{LogName='Security';Id=4624} | Where-Object { $_.Message -match 'robb.stark' }
```

CONFIRM THE FIX

> Privileged logons appear only on the tier-matched jump host and same-tier assets; the alert rule fires on any logon elsewhere.

CLOSES ISO 27001:2022 A.8.2 A.5.18 A.8.18 · DORA Art. 9(4)(c) · ENS op.acc.6 op.acc.3

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

NIS2 Art. 21(2)(i) PCI DSS 4.0 Req. 7 Req. 8 CIS WINDOWS SERVER 2.2.2

REFS

- https://attack.mitre.org/techniques/T1078/002/
- https://learn.microsoft.com/en-us/security/privileged-access-workstations/privileged-access-access-model

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

05 Account Passwords Recovered in This Assessment

F-002 · CRITICAL · Priority 9.1 · CREDENTIAL ACCESS · T1110.002

AFFECTED

- TIER 0 robb.stark
- TIER 2 arya.stark
- TIER 2 brandon.stark
- TIER 2 hodor
- TIER 2 jon.snow
- TIER 2 rickon.stark
- TIER 2 samwell.tarly
- TIER 2 sansa.stark

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

PRIMARY Reset the named accounts, then block breached passwords at the point of change

STEPS

1. Reset every administrative account on the list first, with a new password set by an administrator rather than a change-at-logon flag, so the window does not stay open until the user next signs in.
2. Reset the remaining accounts with change-at-logon, and communicate it as a scheduled action so the volume does not read as an outage.
3. Review sign-in activity for each account before the reset date; a reset is containment, not an answer about what already happened.
4. Deploy Entra Password Protection with the on-premises agent on the domain controllers so a breached or banned password is rejected when a user sets it.
5. Re-run password recovery after the resets to confirm the accounts no longer resolve.

COMMANDS

Force a change at next logon for a standard account.

PowerShell

```
foreach ($account in 'robb.stark', 'arya.stark', 'brandon.stark', 'hodor', 'jon.snow',
'rickon.stark', 'samwell.tarly', 'sansa.stark') { Set-ADUser $account -ChangePasswordAtLogon
$true }
```

Run this once. It covers all 8 affected accounts.

Set a new password immediately for an administrative account.

PowerShell

```
foreach ($account in 'robb.stark', 'arya.stark', 'brandon.stark', 'hodor', 'jon.snow',
'rickon.stark', 'samwell.tarly', 'sansa.stark') { Set-ADAccountPassword -Identity $account -
Reset }
```

Run this once. It covers all 8 affected accounts.

What the account is and when it last signed in.

PowerShell

```
foreach ($account in 'robb.stark', 'arya.stark', 'brandon.stark', 'hodor', 'jon.snow',
'rickon.stark', 'samwell.tarly', 'sansa.stark') { Get-ADUser $account -Properties
LastLogonDate,MemberOf,PasswordLastSet }
```

Run this once. It covers all 8 affected accounts.

Confirm the password-protection agent is running on a DC.

PowerShell

```
Get-Service AzureADPasswordProtectionDCAgent
```

CONFIRM THE FIX

> Every named account shows a password set after the reset, the password-protection agent is running on each domain controller, and a new password-recovery run resolves none of them.

PasswordLastSet shows a date after the reset.

PowerShell

```
foreach ($account in 'robb.stark', 'arya.stark', 'brandon.stark', 'hodor', 'jon.snow',
'rickon.stark', 'samwell.tarly', 'sansa.stark') { Get-ADUser $account -Properties
PasswordLastSet | Select-Object SamAccountName,PasswordLastSet }
```

Run this once. It covers all 8 affected accounts.

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

FALLBACK

Contain the administrative accounts now and schedule the rest

When: If the number of affected accounts makes a single coordinated reset impractical, or a service account's password is embedded in an application you cannot change today

STEPS

1. Reset the administrative accounts immediately. These are not schedulable: the blast radius is the role, not the user.
2. For a service account whose password is embedded somewhere, record the dependency, then either migrate it to a group managed service account so the directory rotates the password itself, or schedule a change window with the application owner.
3. Require phishing-resistant multi-factor authentication for every administrative account, so a recovered password alone cannot sign in while the reset programme runs.
4. Apply a fine-grained password policy with a longer minimum length to the administrative groups, then work the ordinary accounts in batches.
5. Track the remaining accounts to closure; a partial reset leaves the finding open on the accounts still named.

COMMANDS

Create a stronger policy for the privileged group.

PowerShell

```
New-ADFineGrainedPasswordPolicy -Name '<new_pso_name>' -Precedence 10 -MinPasswordLength 20 -
ComplexityEnabled $true
Add-ADFineGrainedPasswordPolicySubject -Identity '<new_pso_name>' -Subjects
'<privileged_group>'
```

Fill in `<new_pso_name>` and `<privileged_group>` before running it.

Migrate an embedded service credential to a managed account.

PowerShell

```
New-ADServiceAccount -Name '<new_gmsa_name>' -DNSHostName '<service_host>' -
PrincipalsAllowedToRetrieveManagedPassword '<service_host>$'
```

Fill in `<new_gmsa_name>` and `<service_host>` before running it.

Confirm which accounts still carry the old password date.

PowerShell

```
foreach ($account in 'robb.stark', 'arya.stark', 'brandon.stark', 'hodor', 'jon.snow',
'rickon.stark', 'samwell.tarly', 'sansa.stark') { Get-ADUser $account -Properties
PasswordLastSet | Select SamAccountName,PasswordLastSet }
```

Run this once. It covers all 8 affected accounts.

CONFIRM THE FIX

> Every administrative account on the list shows a PasswordLastSet after the containment date and requires multi-factor authentication; the fine-grained policy is applied to the privileged groups; the remaining accounts have a dated reset plan and the list shrinks on re-assessment.

CLOSES

ISO 27001:2022 A.5.17 A.8.5 DORA Art. 9(4)(d) ENS op.acc.5 op.acc.6 NIS2 Art. 21(2)(i) Art. 21(2)(j) PCI DSS 4.0 Req. 8 CIS WINDOWS SERVER 1.1.4 1.1.5 1.2.2

REFS

- https://attack.mitre.org/techniques/T1110/002/
- https://learn.microsoft.com/en-us/entra/identity/authentication/concept-password-ban-bad-on-premises
- https://pages.nist.gov/800-63-3/sp800-63b.html

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

06 LDAP Signing / Channel Binding Not Hardened

F-004 · HIGH · Priority 8 · LDAP · T1557 T1557.001

AFFECTED

TIER 0 winterfell.north.sevenkingdoms.local (192.168.180.11)

RUNBOOK

PRIMARY Require LDAP signing and enable channel binding on all DCs

STEPS

1. First audit which clients perform unsigned/unprotected LDAP binds so you do not break legacy applications (DCs log Event ID 2887 with a count of such binds; enable the 2889 diagnostic to identify the exact clients).
2. In a GPO linked to the Domain Controllers OU, set 'Domain controller: LDAP server signing requirements' to 'Require signing'.
3. Set 'Domain controller: LDAP server channel binding token requirements' to 'Always' (apply the KB5021131 hardening / 2023 channel-binding enforcement first if the DCs predate it).
4. Run gpupdate, then re-check Event ID 2889 to confirm no remaining unsigned binds before/while widening enforcement.

COMMANDS

In Group Policy, set Computer Configuration > Policies > Windows Settings > Security Settings > Local Policies > Security Options > 'Domain controller: LDAP server signing requirements' to 'Require signing'.

In Group Policy, set '...Domain controller: LDAP server channel binding token requirements' to 'Always'.

Equivalent registry (on each DC).

PowerShell

```
reg add HKLM\SYSTEM\CurrentControlSet\Services\NTDS\Parameters /v LDAPServerIntegrity /t
REG_DWORD /d 2 /f
reg add HKLM\SYSTEM\CurrentControlSet\Services\NTDS\Parameters /v LdapEnforceChannelBinding /t
REG_DWORD /d 2 /f
```

Surface unsigned-bind diagnostics first.

PowerShell

```
reg add "HKLM\SYSTEM\CurrentControlSet\Services\NTDS\Diagnostics" /v "16 LDAP Interface
Events" /t REG_DWORD /d 2 /f
gpupdate /force
```

CONFIRM THE FIX

> Both values read 2 on every domain controller, Event ID 2889 records no unsigned bind, and an unsigned or unbound LDAP relay attempt is rejected.

On each domain controller, LDAPServerIntegrity and LdapEnforceChannelBinding both read 2.

PowerShell

```
reg query HKLM\SYSTEM\CurrentControlSet\Services\NTDS\Parameters /v LDAPServerIntegrity
reg query HKLM\SYSTEM\CurrentControlSet\Services\NTDS\Parameters /v LdapEnforceChannelBinding
```


SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

FALLBACK

Stage channel binding to 'When supported' with an audited exception register

When: If legacy LDAP clients cannot yet perform signed binds or channel binding and would break under full enforcement

STEPS

1. Enable LDAP signing 'Require signing' (most clients support it), but set channel binding to 'When supported' (value 1) rather than 'Always' so non-CBT-capable but otherwise-signed clients continue to work.
2. Record every legacy client that cannot meet the policy in an exception register with an owner and a remediation deadline; upgrade or replace them.
3. Pair with SMB signing + NTLM reduction + coercion mitigations to limit relay even while channel binding is partial, then move to 'Always' once the register is cleared.

COMMANDS

Channel binding 'When supported' (value 1).

PowerShell

```
reg add HKLM\SYSTEM\CurrentControlSet\Services\NTDS\Parameters /v LdapEnforceChannelBinding /t REG_DWORD /d 1 /f
```

In Group Policy, set '...LDAP server channel binding token requirements' to 'When supported'.

Keep signing required.

PowerShell

```
reg add HKLM\SYSTEM\CurrentControlSet\Services\NTDS\Parameters /v LDAPServerIntegrity /t REG_DWORD /d 2 /f
```

CONFIRM THE FIX

> LDAPServerIntegrity=2 and LdapEnforceChannelBinding=1 on DCs; Event ID 3074 (channel-binding 'when supported' would-block) identifies the remaining non-compliant clients for the exception register.

CLOSES

ISO 27001:2022 `A.8.20` `A.8.21` `A.8.5` DORA `Art. 6` `Art. 9(2)` `Art. 9(3)`

ENS `mp.com.2` `mp.com.3` `op.acc.2` NIS2 `Art. 21(2)(e)` `Art. 21(2)(h)`

PCI DSS 4.0 `Req. 1` `Req. 2` `Req. 8` `Req. 11`

CIS WINDOWS SERVER `2.3.5.4` `2.3.5.3` `2.3.11.9`

REFS

- https://learn.microsoft.com/en-us/windows-server/identity/ad-ds/ldap-signing
- https://learn.microsoft.com/en-us/troubleshoot/windows-server/active-directory/enable-ldap-signing-in-windows-server

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

07 LSASS Not Running as a Protected Process (RunAsPPL Disabled)

F-006 · HIGH · Priority 7.5 · CREDENTIAL PROTECTION · T1003.001

AFFECTED

- TIER 0 winterfell.north.sevenkingdoms.local (192.168.180.11)
- TIER 1 castelblack.north.sevenkingdoms.local (192.168.180.22)

RUNBOOK

PRIMARY Enable LSA Protection via Group Policy after an Audit-mode validation

STEPS

1. In a GPO scoped to the target tier, enable 'Configure LSASS to run as a protected process' (or set the RunAsPPL registry value).
2. First deploy in Audit mode where supported so any incompatible LSA plug-in (some smartcard, AV or SSO drivers) is logged rather than blocked.
3. Review the LSASS audit events, remediate or update any flagged driver, then switch the value to Enabled (1).
4. Stage DCs first, then servers, then workstations.

COMMANDS

In Group Policy, set Computer Configuration > Policies > Administrative Templates > System > Local Security Authority > 'Configure LSASS to run as a protected process' to Enabled with UEFI lock. Equivalent registry (enforce).

PowerShell

```
reg add HKLM\SYSTEM\CurrentControlSet\Control\Lsa /v RunAsPPL /t REG_DWORD /d 1 /f
```

Audit mode first (where supported).

PowerShell

```
reg add HKLM\SYSTEM\CurrentControlSet\Control\Lsa /v RunAsPPL /t REG_DWORD /d 2 /f
gpupdate /force
```

CONFIRM THE FIX

> RunAsPPL reads 1, and after a reboot the System log records event ID 12 from WinInit stating that LSASS started as a protected process.

Returns 1 on the host.

PowerShell

```
foreach ($targetHost in 'castelblack.north.sevenkingdoms.local',
'winterfell.north.sevenkingdoms.local') { Invoke-Command -ComputerName $targetHost -
ScriptBlock { Get-ItemProperty -Path 'HKLM:\SYSTEM\CurrentControlSet\Control\Lsa' -Name
RunAsPPL } }
```

Run this once. It covers both affected hosts.

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

FALLBACK

Deploy Credential Guard where the hardware supports it

When: On modern, UEFI + virtualization-capable hardware where a stronger isolation than RunAsPPL is warranted

STEPS

1. Confirm the host meets the Credential Guard hardware requirements (UEFI, Secure Boot, virtualization extensions).
2. Enable Virtualization Based Security and Credential Guard via GPO, staged DCs-first like the RunAsPPL rollout.
3. Validate that virtualization-based security is running before widening scope.
4. Keep RunAsPPL enabled as the baseline on any host that cannot run Credential Guard.

COMMANDS

GPO path: Computer Configuration > Policies > Administrative Templates > System > Device Guard > 'Turn On Virtualization Based Security' = Enabled, Credential Guard = Enabled with UEFI lock.

CONFIRM THE FIX

> Credential Guard is running on the host.

SecurityServicesRunning includes 1 (Credential Guard).

PowerShell

```
foreach ($targetHost in 'castelblack.north.sevenkingdoms.local',
'winterfell.north.sevenkingdoms.local') { Invoke-Command -ComputerName $targetHost -
ScriptBlock { Get-CimInstance -ClassName Win32_DeviceGuard -Namespace
root\Microsoft\Windows\DeviceGuard | Select-Object SecurityServicesRunning } }
```

Run this once. It covers both affected hosts.

CLOSES

ISO 27001:2022 `A.8.24` `A.5.17` DORA `Art. 9(4)(d)` `Art. 9(3)` ENS `op.exp.2` `mp.com.2`

NIS2 `Art. 21(2)(h)` `Art. 21(2)(i)` PCI DSS 4.0 `Req. 3` `Req. 8` `Req. 2`

CIS WINDOWS SERVER `18.9.26.2`

REFS

- https://learn.microsoft.com/en-us/windows-server/security/credentials-protection-and-management/configuring-additional-lsa-protection
- https://attack.mitre.org/techniques/T1003/001/

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

08 Credentials Stored in Directory Account Attributes

F-008 · HIGH · Priority 7 · CREDENTIAL EXPOSURE · T1552

AFFECTED

TIER 2 samwell.tarly · description

RUNBOOK

PRIMARY Remove the secrets from the attributes and rotate them

STEPS

1. Review each flagged account before clearing: some descriptions hold operational notes that need to be moved rather than deleted.
2. Clear credential material from description, info, userPassword, unixUserPassword, and any custom attribute holding secrets.
3. Rotate every exposed credential, treating it as compromised (these attributes are world-readable to authenticated users, and in some directories to anonymous readers).
4. Add a recurring directory query for secret-like keywords to catch recurrence.

COMMANDS

Find likely secrets in common attributes.

PowerShell

```
Get-ADUser -Filter * -Properties description,info | Where-Object { $_.description -match 'pass|pwd|secret' -or $_.info -match 'pass|pwd|secret' }
```

Clear a description that held a password.

PowerShell

```
Set-ADUser samwell.tarly -Clear description
```

Rotate the account whose password was exposed.

PowerShell

```
Set-ADAccountPassword -Identity samwell.tarly -Reset -NewPassword (Read-Host -AsSecureString 'New password')
```

CONFIRM THE FIX

> A re-run of the keyword query returns no matches; the rotated credentials no longer authenticate with the exposed value.

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

FALLBACK

Mark sensitive attributes confidential while cleaning up

When: If an application reads a custom attribute that must hold a token temporarily

STEPS

1. Mark the attribute confidential (searchFlags bit 0x80) so only principals with explicit control access can read it, removing the world-readable exposure.
2. Migrate the secret to a managed vault and have the app read it from there.
3. Rotate the exposed value now.

COMMANDS

Mark an attribute confidential (searchFlags |= 0x80 = 128; preserve existing flag bits).

PowerShell

```
Set-ADObject -Identity 'CN=app-
token,CN=Schema,CN=Configuration,DC=north,DC=sevenkingdoms,DC=local' -Replace
@{searchFlags=128}
```

CONFIRM THE FIX

> A standard authenticated user can no longer read the attribute, because the confidential flag denies it, and the secret is served from the vault.

Run as a standard user, the attribute comes back empty.

PowerShell

```
Get-ADObject -Identity <object_dn> -Properties <attribute_name>
```

Fill in `<object_dn>` and `<attribute_name>` before running it.

FALLBACK

Close the unauthenticated read path while the cleanup runs

When: If the directory answers anonymous binds or unauthenticated account enumeration and the cleanup will take more than one maintenance window

STEPS

1. Confirm whether an unauthenticated query returns these attributes: that is the difference between a domain-user exposure and a network-wide one, and it decides how urgent the rotation is.
2. Remove the anonymous read grant from dsHeuristics (the 7th character governs anonymous bind) and confirm the restrict-anonymous policy on the domain controllers, so a credential is required at minimum.
3. Rotate the highest-privilege accounts in the flagged list first, regardless of the bind change: a value already readable without a credential must be treated as known.

COMMANDS

Read the current dsHeuristics value.

PowerShell

```
Get-ADObject -Identity ('CN=Directory Service,CN=Windows NT,CN=Services,' + (Get-
ADRootDSE).configurationNamingContext) -Properties dsHeuristics
```

Confirm the restrict-anonymous policy on a domain controller.

PowerShell

```
Get-ItemProperty 'HKLM:\SYSTEM\CurrentControlSet\Control\Lsa' -Name
restrictanonymous,restrictanonymoussam
```

CONFIRM THE FIX

> An unauthenticated directory query no longer returns user objects or their description and info attributes; the flagged list shrinks to zero over the cleanup schedule.

CLOSES

ISO 27001:2022 A.5.17 A.8.3 A.8.5 DORA Art. 9(2) Art. 9(4)(d)

ENS op.acc.5 mp.com.2 NIS2 Art. 21(2)(i) Art. 21(2)(h)

PCI DSS 4.0 Req. 3 Req. 7 Req. 8

REFS

- https://attack.mitre.org/techniques/T1552.004/

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

09 noPac/sAMAccountName Spoofing (CVE-2021-42278 + CVE-2021-42287)

F-011 · HIGH · Priority 7 · CVE · T1068 T1558

AFFECTED

WHAT IT EXPOSES

TIER 0 winterfell.north.sevenkingdoms.local (192.168.180.11) *vulnerable-host*

RUNBOOK

PRIMARY Patch all Domain Controllers (the only complete fix)

STEPS

1. Apply the November 2021 (or later cumulative) security updates on EVERY Domain Controller: both KB5008380 (the initial fix) and the DC-specific update for the OS version are required to close the two chained CVEs.
2. Confirm every writable DC is patched; a single unpatched DC leaves the chain exploitable because the attacker can target that KDC.
3. Reboot DCs as the update requires and verify the build/hotfix is present.
4. Keep monitoring Event IDs 4741/4742 for sAMAccountName values that collide with DC names during and after rollout.

COMMANDS

Confirm the patch is installed on each DC (replace KB as appropriate for the OS). And the OS-specific DC update.

PowerShell

```
Get-HotFix -Id KB5008380
```

Inventory DC patch levels from one management host.

PowerShell

```
Get-ADDomainController -Filter * | ForEach-Object { Invoke-Command -ComputerName $_.HostName -ScriptBlock { (Get-HotFix | Sort InstalledOn -Desc | Select -First 5) } }
```

Hunt for the spoofing primitive in the Security log.

PowerShell

```
Get-WinEvent -FilterHashtable @{LogName='Security';Id=4741,4742} -MaxEvents 200 | ? { $_.Message -match 'SAM Account Name' }
```

CONFIRM THE FIX

> Every domain controller carries the required updates, and a new ADscan scan no longer reports noPac.

Lists the update on the domain controller.

PowerShell

```
Get-HotFix -Id KB5008380 -ComputerName winterfell.north.sevenkingdoms.local
```


SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

FALLBACK

Remove the prerequisite by setting ms-DS-MachineAccountQuota to 0

When: As a hardening measure while patching is scheduled, or where a legacy DC cannot yet be patched

STEPS

1. Set ms-DS-MachineAccountQuota to 0 on the domain object so standard users can no longer create the machine account the attack relies on (this does NOT fix the underlying CVEs; it removes the default creation path).
2. Where specific teams genuinely need to domain-join machines, grant the 'Create Computer Objects' / 'Add workstations to domain' right to a delegated group on a specific OU instead of relying on the quota.
3. Treat this strictly as a stopgap and complete the patching in the Primary option: an attacker who already controls a machine account can still chain the CVEs.

COMMANDS

Read the current quota.

PowerShell

```
Get-ADObject (Get-ADDomain).DistinguishedName -Properties ms-DS-MachineAccountQuota
```

Set it to 0.

PowerShell

```
Set-ADDomain -Identity north.sevenkingdoms.local -Replace @{'ms-DS-MachineAccountQuota'=0}
```

Delegate join rights to a specific group on an OU instead (GUI: dsa.msc > OU > Delegate Control > 'Create/delete Computer objects').

CONFIRM THE FIX

> The machine account quota reads 0 and a standard user can no longer add a computer to the domain. This is a mitigation only: the updates remain required.

ms-DS-MachineAccountQuota reads 0.

PowerShell

```
Get-ADObject (Get-ADDomain).DistinguishedName -Properties ms-DS-MachineAccountQuota | Select-Object ms-DS-MachineAccountQuota
```

CLOSES

ISO 27001:2022 A.8.8 A.8.5 DORA Art. 9(2) Art. 9(4)(f) ENS op.acc.5 op.acc.3 NIS2 Art. 21(2)(e) Art. 21(2)(i) PCI DSS 4.0 Req. 6 Req. 8 Req. 11 CIS WINDOWS SERVER 2.2.48 2.3.6.5

REFS

- https://msrc.microsoft.com/update-guide/vulnerability/CVE-2021-42287
- https://msrc.microsoft.com/update-guide/vulnerability/CVE-2021-42278
- https://nvd.nist.gov/vuln/detail/CVE-2021-42287
- https://nvd.nist.gov/vuln/detail/CVE-2021-42278
- https://exploit.ph/cve-2021-42287-cve-2021-42278-weaponisation.html

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

10 PrintNightmare (CVE-2021-34527) Exposure in the Print Spooler

F-010 · HIGH · Priority 7 · CVE · T1068

AFFECTED

WHAT IT EXPOSES

TIER 0 `winterfell.north.sevenkingdoms.local (192.168.180.11)` *vulnerable-host*

RUNBOOK

PRIMARY Patch and disable the Print Spooler where unused

STEPS

1. Apply the CVE-2021-34527 updates on all hosts.
2. Disable the Print Spooler service on Domain Controllers and any server that does not print.
3. Restrict point-and-print driver installation to administrators via the package-point-and-print policy.

COMMANDS

Disable the spooler where print is not needed (especially DCs).

PowerShell

```
Set-Service -Name Spooler -StartupType Disabled; Stop-Service Spooler
```

Restrict driver installs to admins (RestrictDriverInstallationToAdministrators).

PowerShell

```
reg add 'HKLM\SOFTWARE\Policies\Microsoft\Windows NT\Printers\PointAndPrint' /v
RestrictDriverInstallationToAdministrators /t REG_DWORD /d 1 /f
```

CONFIRM THE FIX

> The Print Spooler is stopped and disabled on the domain controllers, and driver installation is limited to administrators where the spooler must stay on.

Stopped and Disabled on the host.

PowerShell

```
Invoke-Command -ComputerName winterfell.north.sevenkingdoms.local -ScriptBlock { Get-Service
Spooler | Select-Object Status,StartType }
```

FALLBACK Block remote spooler connections where printing must stay enabled

When: If a print server genuinely needs the spooler running

STEPS

1. Keep the spooler only on dedicated print servers, patched and hardened.
2. Use the 'Allow Print Spooler to accept client connections' policy to stop remote RPC where local printing suffices.
3. Restrict the directory from which printer drivers can load to a trusted, admin-controlled path.

COMMANDS

Disable inbound client connections to the spooler (RegisterSpoolerRemoteRpcEndPoint).

PowerShell

```
reg add 'HKLM\SOFTWARE\Policies\Microsoft\Windows NT\Printers' /v
RegisterSpoolerRemoteRpcEndPoint /t REG_DWORD /d 2 /f
Restart-Service Spooler
```

CONFIRM THE FIX

> The host no longer accepts remote AddPrinterDriverEx RPC; a PrintNightmare check (review-only) against it fails to load a remote driver.

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

CLOSES

ISO 27001:2022 A.8.8 A.8.9 DORA Art. 9(4)(f) ENS op.exp.4 NIS2 Art. 21(2)(e)

PCI DSS 4.0 Req. 2 Req. 6 Req. 11 CIS WINDOWS SERVER 18.7.1 5.1

REFS

- https://msrc.microsoft.com/update-guide/vulnerability/CVE-2021-34527
- https://nvd.nist.gov/vuln/detail/CVE-2021-34527
- https://attack.mitre.org/techniques/T1068/

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

11 Child Domain Can Escalate to Forest Root (Intra-Forest Trust)

F-007 · HIGH · Priority 7 · TRUST · T1134.005

AFFECTED

WHAT IT EXPOSES

`sevenkingdoms.local` *forest-root-domain*

RUNBOOK

PRIMARY Treat the whole forest as one Tier-0 boundary

STEPS

1. Map the forest's domain topology and trust relationships with the RSAT ActiveDirectory module so every child domain and its administrators are known.
2. Administer, monitor, and restrict every child domain to the same standard as the forest root: a child-domain administrator is effectively an Enterprise Admin.
3. Minimise and tightly control membership of each child domain's administrative groups, and apply Tier-0 protections (Protected Users, privileged access workstations) forest-wide.

COMMANDS

Enumerate the forest, its domains and trusts.

PowerShell

```
Get-ADForest | Format-List Name,RootDomain,Domains
Get-ADTrust -Filter * | Format-List Name,Direction,IntraForest,ForestTransitive
```

CONFIRM THE FIX

> Each child domain's administrative group membership is reviewed and constrained to the same standard as the forest root, and no unaccounted principal can administer a child domain.

FALLBACK Split into separate forests

When: when two resource sets have genuinely different security requirements that a single forest cannot honour

STEPS

1. Design a separate forest for the resource set that needs an independent security boundary.
2. Migrate the resources across the new forest trust, where SID filtering / quarantine CAN be enforced (it cannot be applied inside one forest).
3. Decommission the child domain once migration is complete.

COMMANDS

On the trusting forest, confirm SID filtering is enforced on the new EXTERNAL/forest trust.

PowerShell

```
Get-ADTrust -Identity <partner.forest.root> -Properties
SIDFilteringForestAware,SIDFilteringQuarantined
```

Fill in `<partner.forest.root>` before running it.

CONFIRM THE FIX

> The separated resources live in a distinct forest whose trust enforces SID filtering, so a compromise on one side no longer injects the other side's privileged SID history.

CLOSES

ISO 27001:2022 `A.5.18` `A.8.2` `A.8.22` DORA `Art. 9(2)` `Art. 9(4)(c)` ENS `op.acc.4` `org.4`

NIS2 `Art. 21(2)(i)` PCI DSS 4.0 `Req. 1` `Req. 7` `Req. 8` `Req. 11`

CIS WINDOWS SERVER `2.2.28` `2.2.48`

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

REFS

- https://attack.mitre.org/techniques/T1134/005/
- https://learn.microsoft.com/en-us/security/privileged-access-workstations/privileged-access-access-model
- https://adsecurity.org/?p=1640

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

12 Sensitive Data Found in SMB Shares

F-009 · HIGH · Priority 7 · SMB · T1552.001

AFFECTED

- TIER 1 jeor.mormont
- Share: \\WINTERFELL.north.sevenkingdoms.local\NETLOGON\script.ps1
- Share: \\WINTERFELL.north.sevenkingdoms.local\NETLOGON\secret.ps1
- Share: \\WINTERFELL.north.sevenkingdoms.local\SYSVOL\north.sevenkingdoms.local\scripts\script.p
- Share: \\WINTERFELL.north.sevenkingdoms.local\SYSVOL\north.sevenkingdoms.local\scripts\secret.p

DETAIL

- Share: \\WINTERFELL.north.sevenkingdoms.local\NETLOGON\script.ps1

RUNBOOK

PRIMARY **Rotate the exposed secrets and remove them from the shares**

STEPS

1. Rotate every credential, key, and token found in the shared files immediately, treating them as compromised.
2. Delete the secret material from the files and move it into a managed secrets store (Key Vault, HashiCorp Vault, CyberArk).
3. Tighten share and NTFS ACLs to least privilege, removing broad Everyone or Authenticated Users read.

COMMANDS

Tighten a share to a named group, read-only.

PowerShell

```
Revoke-SmbShareAccess -Name 'NETLOGON' -AccountName 'Authenticated Users' -Force
Grant-SmbShareAccess -Name 'NETLOGON' -AccountName 'NORTH\<authorized_group>' -AccessRight
Read -Force
```

Fill in `<authorized_group>` before running it.

Scan shares for residual secrets (review-only tooling). E.g. run a secret scanner across the mounted share path.

CONFIRM THE FIX

> A re-scan of the shares finds no plaintext credentials; the rotated secrets are served only from the managed vault.

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

FALLBACK

Restrict access and add continuous secret scanning

When: If the files cannot be moved immediately because a legacy deployment reads them in place

STEPS

1. Reduce the share ACL to the single service identity that consumes the file and enable access auditing.
2. Encrypt the file at rest and restrict NTFS read to that identity only.
3. Schedule automated secret scanning so any new exposure is flagged quickly, and plan migration to a vault.

COMMANDS

Lock NTFS to one service account.

PowerShell

```
$File = Join-Path (Get-SmbShare -Name 'NETLOGON').Path 'script.ps1'
icacls $File /inheritance:r /grant 'NORTH\<service_account>:(R)'
```

Fill in `<service_account>` before running it.

Enable object-access auditing on the path (SACL). Advanced Audit Policy > Object Access > Audit File System = Success/Failure.

CONFIRM THE FIX

> Only the service identity can read the file (icacls output); the scheduled secret scan reports no broadly-readable credential files.

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

WHEN ADSCAN PROVED THE FILE WAS REACHABLE WITH NO DOMAIN CREDENTIAL AT ALL, OVER AN SMB GUEST OR NULL SESSION

Close a proven no-credential access path (SMB guest or null session)

STEPS

1. For a guest-session read: remove the Everyone grant AND the explicit Guest/Guests grant from both the share ACL and the underlying NTFS folder's DACL, since either one left in place still lets the guest logon through, then disable the built-in Guest account so guest logon cannot be re-enabled as a workaround.
2. For a null-session read: this is a server-wide policy setting, not a share ACE, so close it in the registry: set RestrictNullSessAccess to 1, remove the share's name from NullSessionShares, and disable EveryoneIncludesAnonymous where it is enabled.

COMMANDS

Guest-session read: remove the credential-less grants (repeat on the NTFS folder with icacls).

PowerShell

```
Revoke-SmbShareAccess -Name 'NETLOGON' -AccountName 'Everyone' -Force
Revoke-SmbShareAccess -Name 'NETLOGON' -AccountName 'Guest' -Force
Get-LocalUser -Name Guest | Disable-LocalUser
```

Null-session read: harden the server-wide policy.

PowerShell

```
Set-ItemProperty -Path 'HKLM:\SYSTEM\CurrentControlSet\Services\LanmanServer\Parameters' -Name
RestrictNullSessAccess -Value 1
Set-ItemProperty -Path 'HKLM:\SYSTEM\CurrentControlSet\Control\Lsa' -Name
EveryoneIncludesAnonymous -Value 0
```

CONFIRM THE FIX

> The share and its folder grant nothing to Everyone or Guest, the local Guest account is disabled, and null sessions are restricted.

Neither Everyone nor Guest is listed.

PowerShell

```
Get-SmbShareAccess -Name 'NETLOGON'
```

Enabled reads False.

PowerShell

```
Get-LocalUser -Name Guest | Select-Object Name,Enabled
```

Returns 1.

PowerShell

```
Get-ItemProperty 'HKLM:\SYSTEM\CurrentControlSet\Services\LanmanServer\Parameters' -Name
RestrictNullSessAccess
```

CLOSES

ISO 27001:2022 A.5.17 A.8.3 DORA Art. 9(4)(d) ENS mp.com.2 op.exp.2

NIS2 Art. 21(2)(i) PCI DSS 4.0 Req. 3 Req. 7 Req. 8

CIS WINDOWS SERVER 2.3.10.12 2.3.10.5

REFS

- https://attack.mitre.org/techniques/T1552/001/
- https://learn.microsoft.com/en-us/windows-server/storage/file-server/best-practices-analyzer/smb-open-file-security-policies

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

13 Accounts with Non-Expiring Passwords

F-012 · MEDIUM · Priority 6.5 · POLICY · T1078

AFFECTED

TIER 0 Administrator · TIER 0 catelyn.stark · TIER 0 eddard.stark · TIER 0 robb.stark · TIER 1 sql_svc · TIER 1 jeor.mormont · TIER 2 adscan · TIER 2 arya.stark · TIER 2 brandon.stark · TIER 2 hodor · TIER 2 jon.snow · TIER 2 rickon.stark · TIER 2 samwell.tarly · TIER 2 sansa.stark

RUNBOOK

PRIMARY Remove DONT_EXPIRE_PASSWORD from standard accounts

STEPS

1. List accounts with DONT_EXPIRE_PASSWORD set (userAccountControl bit 0x10000 = 65536).
2. Remove the flag from standard user accounts so the domain expiration policy applies again.
3. Confirm each account still has a valid business owner.

COMMANDS

Find accounts with the non-expiring flag (65536).

PowerShell

```
Get-ADUser -Filter 'Enabled -eq $true -and userAccountControl -band 65536' -Properties
userAccountControl
```

Clear it (toggles only the password-never-expires bit).

PowerShell

```
Set-ADUser -Identity <user> -PasswordNeverExpires $false
```

Fill in `<user>` before running it.

CONFIRM THE FIX

> The account's password expires again under the domain's maximum password age.

PasswordNeverExpires reads False.

PowerShell

```
Get-ADUser adscan -Properties PasswordNeverExpires | Select-Object
SamAccountName,PasswordNeverExpires
```

Shown for adscan. Run it for each of the 14 affected accounts, with that account's own values. The full list is under Affected Assets.

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

FALLBACK

Move static-password service accounts to gMSA or a rotation schedule

When: If a service account genuinely needs a non-expiring password

STEPS

1. Migrate the service to a Group Managed Service Account, which rotates its password automatically and never needs the flag.
2. Where gMSA is not possible, keep the flag but enforce a documented manual rotation at least annually.
3. Set a long random password now and record the account in an exception register.

COMMANDS

Create and assign a gMSA (effective after the KDS root key replicates).

PowerShell

```
New-ADServiceAccount -Name <new_gmsa_name> -DNSHostName <service_host_fqdn> -
PrincipalsAllowedToRetrieveManagedPassword '<service_host>$'
Install-ADServiceAccount -Identity <new_gmsa_name>
```

Fill in `<new_gmsa_name>`, `<service_host_fqdn>` and `<service_host>` before running it.

CONFIRM THE FIX

> The gMSA works on the service host, and the old static-password account is retired or in the rotation register.

On the service host, this returns True.

PowerShell

```
Test-ADServiceAccount -Identity <new_gmsa_name>
```

Fill in `<new_gmsa_name>` before running it.

CLOSES

ISO 27001:2022 `A.5.17` DORA `Art. 6` `Art. 9(4)(d)` ENS `op.acc.5`

NIS2 `Art. 21(2)(j)` `Art. 21(2)(i)` PCI DSS 4.0 `Req. 8` `Req. 12` CIS WINDOWS SERVER `1.1.2`

REFS

- https://attack.mitre.org/techniques/T1078/
- https://learn.microsoft.com/en-us/microsoft-365/admin/misc/password-policy-recommendations

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

14 Passwords Predating Current Policy

F-013 · MEDIUM · Priority 6 · IDENTITY HYGIENE · T1078

AFFECTED

- TIER 0 Administrator · Password set 2026-05-01 (~193 days ago)
- TIER 0 catelyn.stark · Password set 2026-05-01 (~193 days ago)
- TIER 0 eddard.stark · Password set 2026-05-01 (~193 days ago)
- TIER 0 robb.stark · Password set 2026-05-01 (~193 days ago)
- TIER 1 sql_svc · Password set 2026-05-01 (~193 days ago)
- TIER 1 jeor.mormont · Password set 2026-05-01 (~193 days ago)
- TIER 2 arya.stark · Password set 2026-05-01 (~193 days ago)
- TIER 2 brandon.stark · Password set 2026-05-01 (~193 days ago)
- TIER 2 hodor · Password set 2026-05-01 (~193 days ago)
- TIER 2 jon.snow · Password set 2026-05-01 (~193 days ago)
- TIER 2 rickon.stark · Password set 2026-05-01 (~193 days ago)
- TIER 2 samwell.tarly · Password set 2026-05-01 (~193 days ago)
- TIER 2 sansa.stark · Password set 2026-05-01 (~193 days ago)

RUNBOOK

PRIMARY

Force a reset on accounts whose pwdLastSet predates the policy change

STEPS

1. Identify the date the Default Domain Policy or the relevant PSO last changed, then list enabled accounts whose pwdLastSet is older than that.
2. Reset Tier-0, Domain Admin, and service accounts first, then the remaining users on a defined schedule.
3. For bulk user resets, set 'User must change password at next logon' so the new credential is chosen under the current policy.

COMMANDS

List enabled users whose password predates a cutoff date.

PowerShell

```
Get-ADUser -Filter "Enabled -eq $true -and pwdLastSet -lt 0" -Properties pwdLastSet | Where-Object { [DateTime]::FromFileTime($_.pwdLastSet) -lt (Get-Date '2024-01-01') }
```

Flag a user to change password at next logon.

PowerShell

```
Set-ADUser <user> -ChangePasswordAtLogon $true
```

Fill in `<user>` before running it.

CONFIRM THE FIX

> Re-run the query; PasswordLastSet for each remediated account is now later than the policy change date.

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

FALLBACK

Stage resets through a Fine-Grained Password Policy

When: If a flag-day reset would disrupt service accounts or non-interactive identities

STEPS

1. Create a PSO that enforces the current minimum length and maximum age, and apply it to the affected population.
2. Exempt break-glass and documented service accounts, tracking them in an exception register with a manual rotation schedule.
3. Let maximum-age expiry drive the rotation gradually instead of forcing every account at once.

COMMANDS

PowerShell

```
New-ADFineGrainedPasswordPolicy -Name CurrentBaseline -Precedence 10 -MinPasswordLength 14 -
MaxPasswordAge 90.00:00:00
Add-ADFineGrainedPasswordPolicySubject CurrentBaseline -Subjects 'NORTH\
<affected_users_group>'
```

Fill in `<affected_users_group>` before running it.

CONFIRM THE FIX

> The fine-grained policy lists its subjects, and the affected accounts rotate to a compliant password at their next expiry.

The policy applies to the affected accounts' group.

PowerShell

```
Get-ADFineGrainedPasswordPolicySubject -Identity CurrentBaseline
```

CLOSES

ISO 27001:2022 A.5.17 A.8.5 DORA Art. 6 Art. 9(4)(d) ENS op.acc.5 op.acc.4 NIS2 Art. 21(2)(j) Art. 21(2)(i) PCI DSS 4.0 Req. 8 Req. 12 CIS WINDOWS SERVER 1.1.1 1.1.2

REFS

- https://learn.microsoft.com/en-us/windows/security/identity-protection/access-control/active-directory-accounts
- https://attack.mitre.org/techniques/T1078/

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

15 Kerberos Web Service (HTTP SPN) Relay and Coercion Surface

F-018 · MEDIUM · Priority 4 · KERBEROS · T1187 T1557

AFFECTED

TIER 1 castelblack.north.sevenkingdoms.local (192.168.180.22) · HTTP/winterfell.north.sevenkingdoms.local

RUNBOOK

PRIMARY Harden the authentication channels and the web endpoint

STEPS

1. Enumerate the HTTP SPNs so you know exactly which accounts publish a Kerberos web service and on which hosts.
2. For each endpoint that must stay, enable Extended Protection for Authentication (service/channel binding) in the web server (IIS: Windows Authentication → Advanced Settings → Extended Protection = Required) and serve it over HTTPS only.
3. Enforce LDAP signing and LDAP channel binding on every Domain Controller and require SMB signing domain-wide, so a captured authentication has no unsigned service to be forwarded to.
4. Re-run discovery and confirm the HTTP SPN inventory matches the documented, hardened services.

COMMANDS

List every HTTP SPN and the account that owns it.

PowerShell

```
Get-ADObject -LDAPFilter '(servicePrincipalName=HTTP/*)' -Properties
sAMAccountName,servicePrincipalName | Format-List sAMAccountName,servicePrincipalName
```

Inspect the SPNs registered on a specific account.

PowerShell

```
setspn -L castelblack$
```

Require LDAP signing + channel binding on Domain Controllers (GPO): Computer Configuration > Policies > Windows Settings > Security Settings > Local Policies > Security Options > 'Domain controller: LDAP server signing requirements' = 'Require signing' and 'Domain controller: LDAP server channel binding token requirements' = 'Always'. Require SMB signing domain-wide (GPO): 'Microsoft network server: Digitally sign communications (always)' = Enabled.

CONFIRM THE FIX

> Only documented web services carry an HTTP SPN, SMB signing is required, and the web endpoint reports Extended Protection as Required.

Lists only the documented web services.

PowerShell

```
Get-ADObject -LDAPFilter '(servicePrincipalName=HTTP/*)' -Properties servicePrincipalName |
Select-Object Name,servicePrincipalName
```


SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

FALLBACK

Reduce the surface: retire and de-privilege HTTP SPNs

When: When an endpoint cannot enable Extended Protection or must remain on legacy authentication

STEPS

1. Remove HTTP SPNs that belong to decommissioned or unrecognised web services so they no longer present a Kerberos endpoint.
2. Move any remaining web service to a dedicated, low-privilege account (or a group managed service account) rather than a privileged or shared account.
3. Add the DCs and Tier-0 / privileged accounts to the Protected Users group and mark sensitive accounts 'Account is sensitive and cannot be delegated' so their authentications are non-forwardable regardless of the endpoint.
4. Reduce forced-authentication vectors (patch and disable the Print Spooler on DCs, apply RPC filters) so a privileged account cannot be coerced to the endpoint in the first place.

COMMANDS

Remove a stale HTTP SPN from an account.

PowerShell

```
setspn -D HTTP/winterfell.north.sevenkingdoms.local 'castelblack$'
```

Mark a privileged account non-delegatable (sets NOT_DELEGATED).

PowerShell

```
Set-ADAccountControl -Identity <privileged_account> -AccountNotDelegated $true
```

Fill in `<privileged_account>` before running it.

Add a privileged account to Protected Users.

PowerShell

```
Add-ADGroupMember -Identity 'Protected Users' -Members <privileged_account>
```

Fill in `<privileged_account>` before running it.

Disable the Print Spooler coercion vector on a DC.

PowerShell

```
Set-Service -Name Spooler -StartupType Disabled; Stop-Service -Name Spooler
```

CONFIRM THE FIX

> The retired services no longer carry an HTTP SPN, the privileged accounts cannot be delegated, and Protected Users includes the domain controllers and privileged accounts.

The retired services are no longer listed.

PowerShell

```
Get-ADObject -LDAPFilter '(servicePrincipalName=HTTP/*)' -Properties servicePrincipalName |
Select-Object Name,servicePrincipalName
```

CLOSES

ISO 27001:2022 `A.8.20` `A.8.5` `A.8.22` DORA `Art. 9(4)(b)` ENS `mp.com.3` `mp.com.2`
NIS2 `Art. 21(2)(h)` `Art. 21(2)(e)` PCI DSS 4.0 `Req. 1` `Req. 2` `Req. 4` `Req. 8` `Req. 11`
CIS WINDOWS SERVER `2.3.9.2` `2.3.8.1` `2.3.5.4` `2.3.5.3` `2.3.9.5`

REFS

- https://attack.mitre.org/techniques/T1187/
- https://attack.mitre.org/techniques/T1557/
- https://learn.microsoft.com/en-us/openspecs/windows_protocols/ms-adts/1be82e63-f4be-4141-b2fb-c8c04a1c8a1e
- https://learn.microsoft.com/en-us/security-updates/securityadvisories/2009/973811

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

16 Domain Does Not Force AES Encryption for Kerberos

F-016 · MEDIUM · Priority 4 · KERBEROS SECURITY · T1558.003

AFFECTED *domain-wide*

RUNBOOK

PRIMARY Commit the domain to AES-only encryption

STEPS

1. Confirm every service account supports AES (msDS-SupportedEncryptionTypes AES bits set), rotating passwords where needed.
2. Set the domain object's msDS-SupportedEncryptionTypes to 24 (AES128 + AES256) so RC4 is no longer a negotiable fallback.
3. Plan a 90-day audit window after enforcement to catch legacy dependencies.

COMMANDS

Enforce AES-only at the domain object (24 = AES128 + AES256).

PowerShell

```
Set-ADObject (Get-ADDomain).DistinguishedName -Replace @{'msDS-SupportedEncryptionTypes'=24}
```

Verify a service account is AES-capable first.

PowerShell

```
Get-ADUser <service_account> -Properties msDS-SupportedEncryptionTypes
```

Fill in `<service_account>` before running it.

CONFIRM THE FIX

> The domain object reports msDS-SupportedEncryptionTypes 24; a client requesting RC4 (review-only) is served AES or refused, never RC4.

FALLBACK Phase enforcement after remediating RC4-only accounts

When: If RC4-only accounts still exist and a hard AES-only switch would break them

STEPS

1. Set each RC4-only account to AES (24) and rotate its password to generate the AES keys.
2. Track readiness in a register; only once all accounts are AES-capable, flip the domain object to AES-only.
3. Monitor Kerberos etype usage during the transition.

COMMANDS

PowerShell

```
Set-ADUser <service_account> -Replace @{'msDS-SupportedEncryptionTypes'=24}
$pw = [System.Web.Security.Membership]::GeneratePassword(28,6)
Set-ADAccountPassword <service_account> -Reset -NewPassword (ConvertTo-SecureString $pw -
AsPlainText -Force)
```

Fill in `<service_account>` before running it.

CONFIRM THE FIX

> Every account in the register reports AES support; etype monitoring shows no RC4 in use before the domain object is set to AES-only.

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

CLOSES

ISO 27001:2022 A.8.5 A.8.24 A.8.20 DORA Art. 6 Art. 9(3) ENS mp.com.2 op.acc.2 NIS2 Art. 21(2)(e) Art. 21(2)(h) PCI DSS 4.0 Req. 2 Req. 8 Req. 11 CIS WINDOWS SERVER 2.3.11.4

REFS

- https://learn.microsoft.com/en-us/windows/security/threat-protection/security-policy-settings/network-security-configure-encryption-types-allowed-for-kerberos
- https://attack.mitre.org/techniques/T1558/003/

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

17 Domain Controller Accepts RC4 Kerberos Encryption

F-015 · MEDIUM · Priority 4 · KERBEROS SECURITY · T1558.003 T1558.004

AFFECTED

TIER 0 winterfell.north.sevenkingdoms.local (192.168.180.11)

RUNBOOK

PRIMARY Restrict Kerberos encryption types to AES only via GPO

STEPS

1. Audit accounts for AES support and rotate passwords on any RC4-only account before enforcing.
2. Set 'Network security: Configure encryption types allowed for Kerberos' to AES128 + AES256 only.
3. Update or isolate legacy systems (pre-Windows 7 / pre-Server 2008 R2) that lack AES.

COMMANDS

GPO Security Option: 'Configure encryption types allowed for Kerberos' = AES128_HMAC_SHA1 + AES256_HMAC_SHA1 + Future types only. Registry equivalent (0x18 = AES128 + AES256).

PowerShell

```
reg add 'HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\System\Kerberos\Parameters'
/v SupportedEncryptionTypes /t REG_DWORD /d 0x18 /f
```

CONFIRM THE FIX

> Tickets for a remediated account are AES, and klist on a client shows AES session keys and no etype 23.

The session keys read AES-256-CTS-HMAC-SHA1-96, never RSADSI RC4-HMAC.

PowerShell

```
klist
```

FALLBACK Stage AES enforcement behind an account-readiness audit

When: If some service accounts are not yet AES-capable

STEPS

1. Enable AES on each account (msDS-SupportedEncryptionTypes) and rotate its password to materialise the AES keys.
2. Verify every SPN-bearing account negotiates AES before flipping the domain GPO to AES-only.
3. Keep a short audit window to catch any legacy client that still requested RC4.

COMMANDS

PowerShell

```
Set-ADUser <service_account> -Replace @{'msDS-SupportedEncryptionTypes'=24}
$pw = [System.Web.Security.Membership]::GeneratePassword(28,6)
Set-ADAccountPassword <service_account> -Reset -NewPassword (ConvertTo-SecureString $pw -
AsPlainText -Force)
```

Fill in `<service_account>` before running it.

CONFIRM THE FIX

> All SPN-bearing accounts show AES in msDS-SupportedEncryptionTypes; a review-only roast yields no RC4 ticket before the domain GPO is enforced.

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

CLOSES

ISO 27001:2022 A.8.5 A.8.24 A.8.20 DORA Art. 6 Art. 9(3) ENS mp.com.2 op.acc.2 NIS2 Art. 21(2)(e) Art. 21(2)(h) PCI DSS 4.0 Req. 2 Req. 4 Req. 8 Req. 11 CIS WINDOWS SERVER 2.3.11.4

REFS

- https://learn.microsoft.com/en-us/windows/security/threat-protection/security-policy-settings/network-security-configure-encryption-types-allowed-for-kerberos
- https://attack.mitre.org/techniques/T1558/003/

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

18 krbtgt Account Password Not Rotated

F-019 · MEDIUM · Priority 4 · KERBEROS SECURITY

AFFECTED

TIER 0 krbtgt · Last rotated 2026-05-01 (~193 days ago)

RUNBOOK

PRIMARY Rotate krbtgt twice and set a recurring schedule

STEPS

1. Rotate the krbtgt password twice with a replication interval between passes.
2. Establish a recurring rotation at least every 180 days using the Microsoft krbtgt reset script or equivalent tooling.
3. Monitor for Kerberos ticket anomalies (unusually long lifetimes, tickets with no matching TGT request).

COMMANDS

First pass (then replicate, verify, second pass).

PowerShell

```
Set-ADAccountPassword -Identity krbtgt -Reset -NewPassword (ConvertTo-SecureString
([System.Web.Security.Membership]::GeneratePassword(32,8)) -AsPlainText -Force)
```

Check current age.

PowerShell

```
Get-ADUser krbtgt -Properties PasswordLastSet | Select PasswordLastSet
```

CONFIRM THE FIX

> KRBTGT's password was set within the last 180 days and shows two recent changes, and the rotation job is scheduled.

PasswordLastSet is within the last 180 days.

PowerShell

```
Get-ADUser krbtgt -Properties PasswordLastSet | Select-Object PasswordLastSet
```

FALLBACK Phase the rotation in a multi-site domain

When: If site-to-site replication is slow and back-to-back rotations risk authentication outages

STEPS

1. Rotate once, then confirm the change has replicated to every DC before the second pass.
2. Schedule the rotations during a low-traffic window per site.
3. Verify replication health between passes.

COMMANDS

PowerShell

```
repadmin /showobjmeta * "CN=krbtgt,CN=Users,DC=north,DC=sevenkingdoms,DC=local"
repadmin /replsummary
```

CONFIRM THE FIX

> The krbtgt version is consistent across all DCs before the second rotation; no authentication outage is observed during the window.

CLOSES

ISO 27001:2022 A.8.5 A.8.2 A.5.17 DORA Art. 6 Art. 9(4)(d)

ENS op.acc.5 mp.com.3 op.exp.10 NIS2 Art. 21(2)(h) Art. 21(2)(i)

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

PCI DSS 4.0 Req. 3 Req. 8 CIS WINDOWS SERVER 2.3.6.5 1.1.2 2.3.5.5

REFS

- https://attack.mitre.org/techniques/T1558.001/
- https://docs.microsoft.com/en-us/windows-server/identity/ad-ds/manage/ad-forest-recovery-resetting-the-krbtgt-password

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

19 Domain Controller Accepts NTLM Authentication

F-014 · MEDIUM · Priority 4 · AUTHENTICATION · T1557 T1557.001 T1550.002

AFFECTED

TIER 0 winterfell.north.sevenkingdoms.local (192.168.180.11)

RUNBOOK

PRIMARY Audit then restrict NTLM toward Kerberos-only

STEPS

1. Enable NTLM auditing to inventory which applications and clients still depend on NTLM (DC events 8001-8004).
2. Remediate the dependencies, then progressively set 'Restrict NTLM: NTLM authentication in this domain' toward Deny all.
3. Pair the reduction with LDAP signing, channel binding, and SMB signing enforcement.

COMMANDS

Audit incoming NTLM first. In Group Policy, set 'Network security: Restrict NTLM: Audit Incoming NTLM Traffic' to 'Enable auditing for all accounts'.

PowerShell

```
Get-WinEvent -LogName 'Microsoft-Windows-NTLM/Operational'
```

Then enforce: 'Restrict NTLM: NTLM authentication in this domain' = Deny all.

CONFIRM THE FIX

> The NTLM Operational log shows the inventory shrinking to zero; after enforcement, an NTLM bind to the DC is refused while Kerberos succeeds.

FALLBACK Add per-server NTLM exceptions for unavoidable legacy apps

When: If a legacy application cannot use Kerberos

STEPS

1. Set the domain policy to Deny all but add the specific servers to the NTLM exception list so only they accept NTLM.
2. Restrict and monitor those servers tightly.
3. Plan migration of the legacy app to Kerberos and remove the exception once done.

COMMANDS

In Group Policy, set 'Restrict NTLM: Add server exceptions in this domain' to the FQDNs of the legacy servers. Confirm the exception scope.

PowerShell

```
Get-WinEvent -LogName 'Microsoft-Windows-NTLM/Operational' | Where-Object { $_.Message -match 'legacyapp' }
```

CONFIRM THE FIX

> NTLM succeeds only against the listed servers; all other DCs and members refuse NTLM. The exception register tracks the migration date.

CLOSES

ISO 27001:2022 A.8.5 A.8.20 A.8.9 DORA Art. 6 Art. 9(3) Art. 9(4)(d)

ENS mp.com.2 mp.com.3 op.acc.2 NIS2 Art. 21(2)(e) Art. 21(2)(h)

PCI DSS 4.0 Req. 2 Req. 8 Req. 11

CIS WINDOWS SERVER 2.3.11.7 2.3.11.10 2.3.11.11 2.3.8.1 2.3.9.2 2.3.9.5

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

REFS

- https://learn.microsoft.com/en-us/windows/security/threat-protection/security-policy-settings/network-security-restrict-ntlm-ntlm-authentication-in-this-domain
- https://attack.mitre.org/techniques/T1557/

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

20 SMB Null Session Authentication on DC

F-022 · MEDIUM · Priority 4 · SMB · T1021.002

AFFECTED *domain-wide*

RUNBOOK

PRIMARY Remove Anonymous Logon from Pre-Windows 2000 Compatible Access

STEPS

1. Inspect the 'Pre-Windows 2000 Compatible Access' built-in group for the 'Anonymous Logon' (S-1-5-7) and 'Everyone' (S-1-1-0) members.
2. Remove 'Anonymous Logon' from the group so null sessions inherit no rights on the Domain Controllers.
3. Set RestrictAnonymous and RestrictAnonymousSAM to 1 via GPO so anonymous SAM and share enumeration is blocked.

COMMANDS

Check membership (S-1-5-7 = Anonymous Logon).

PowerShell

```
Get-ADGroupMember 'Pre-Windows 2000 Compatible Access'
```

Remove Anonymous Logon (use the well-known SID, the name is locale-bound).

PowerShell

```
$g = Get-ADGroup 'Pre-Windows 2000 Compatible Access'
Remove-ADGroupMember -Identity $g -Members (New-Object
System.Security.Principal.SecurityIdentifier 'S-1-5-7') -Confirm:$false
```

In Group Policy, open Computer Config > Policies > Windows Settings > Security Settings > Local Policies > Security Options. 'Network access: Do not allow anonymous enumeration of SAM accounts' = Enabled. 'Network access: Do not allow anonymous enumeration of SAM accounts and shares' = Enabled.

CONFIRM THE FIX

> From an unauthenticated host, run rpcclient with an empty user against the DC and confirm enumdomusers / querydispinfo return STATUS_ACCESS_DENIED instead of the user list.

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

FALLBACK

Strip the ACEs that grant Anonymous Logon access on the DCs

When: If a legacy application still requires the 'Pre-Windows 2000 Compatible Access' group to exist with other members

STEPS

1. Keep the group but remove the Anonymous Logon principal from the specific ACLs that let it authenticate through a null session.
2. Audit the naming-context security descriptors for any ACE granting 'Anonymous Logon' read or list-contents rights.
3. Remove those ACEs and replace with 'Authenticated Users' where the legacy app genuinely needs directory read.

COMMANDS

List ACEs that reference Anonymous Logon on the domain head.

PowerShell

```
(Get-Acl 'AD:\DC=north,DC=sevenkingdoms,DC=local').Access | Where-Object IdentityReference -eq
'NT AUTHORITY\ANONYMOUS LOGON'
```

Remove a specific anonymous ACE with dsacls (review the rule first).

PowerShell

```
dsacls "DC=north,DC=sevenkingdoms,DC=local" /R "NT AUTHORITY\ANONYMOUS LOGON"
```

CONFIRM THE FIX

> No ACE on the domain head names ANONYMOUS LOGON, and a null-session bind no longer returns directory data.

No line names ANONYMOUS LOGON.

PowerShell

```
dsacls "DC=north,DC=sevenkingdoms,DC=local" | findstr /i "ANONYMOUS"
```

CLOSES

ISO 27001:2022 `A.8.20` `A.8.5` DORA `Art. 8` ENS `op.acc.2` `mp.com.3` NIS2 `Art. 21(2)(e)`

PCI DSS 4.0 `Req. 1` `Req. 7` `Req. 8` `Req. 11`

CIS WINDOWS SERVER `2.3.10.10` `2.3.10.2` `2.3.10.12` `2.3.10.11` `2.3.10.1`

REFS

- https://attack.mitre.org/techniques/T1021/002/
- https://learn.microsoft.com/en-us/troubleshoot/windows-server/networking/restrict-anonymous-access-named-pipes-shared-resources

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

21 SMB Signing Not Required

F-021 · MEDIUM · Priority 4 · NETWORK SECURITY · T1557.001

AFFECTED

TIER 1 castelblack.north.sevenkingdoms.local (192.168.180.22)

RUNBOOK

PRIMARY Require SMB signing on both server and client via GPO

STEPS

1. Stage the change DC-first, then servers, then workstations, to limit the chance of an interop surprise.
2. In a GPO scoped to the target tier, enable 'Microsoft network server: Digitally sign communications (always)'.
3. Enable the matching client setting 'Microsoft network client: Digitally sign communications (always)'.
4. Run gpupdate and verify signing is required before widening scope.

COMMANDS

In a Group Policy linked to every tier, go to Computer Configuration > Policies > Windows Settings > Security Settings > Local Policies > Security Options and set both 'Microsoft network server: Digitally sign communications (always)' and 'Microsoft network client: Digitally sign communications (always)' to Enabled. The policy reaches every affected host, so no per-host command is needed.

Where a host is outside Group Policy, set the same two values directly in its registry.

PowerShell

```
reg add HKLM\SYSTEM\CurrentControlSet\Services\LanManServer\Parameters /v
RequireSecuritySignature /t REG_DWORD /d 1 /f
reg add HKLM\SYSTEM\CurrentControlSet\Services\LanmanWorkstation\Parameters /v
RequireSecuritySignature /t REG_DWORD /d 1 /f
```

Apply the policy now instead of waiting for the next refresh.

PowerShell

```
gpupdate /force
```

CONFIRM THE FIX

> Every affected host reports RequireSecuritySignature True, and an SMB negotiation against it reports that message signing is enabled and required.

Returns True on the host once signing is required.

PowerShell

```
Invoke-Command -ComputerName castelblack.north.sevenkingdoms.local -ScriptBlock { Get-
SmbServerConfiguration | Select-Object RequireSecuritySignature }
```

The same check from the network reports 'Message signing enabled and required'.

Linux shell

```
nmap -p445 --script smb2-security-mode castelblack.north.sevenkingdoms.local
```


SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

FALLBACK

Reduce relay reach where a legacy client breaks under enforced signing

When: If an old NAS, printer, or appliance loses connectivity when SMB signing is required on its peers

STEPS

1. Keep signing REQUIRED on Domain Controllers and Tier-0 servers unconditionally: never exempt a DC.
2. Isolate the legacy device on a segmented VLAN with firewall rules that block it from reaching authentication endpoints it does not need.
3. Disable NTLM to/from the legacy device where possible and prefer Kerberos, so a relayed authentication has nothing to relay.
4. Track the device in an exception register with an owner and a replacement deadline; move to the Primary fix once retired.

COMMANDS

DCs stay required regardless of the legacy exception. In the Group Policy linked to the Domain Controllers OU, set '...server: Digitally sign communications (always)' to Enabled.

Block the legacy device from SMB to non-essential hosts (example, adapt to your firewall).

PowerShell

```
New-NetFirewallRule -DisplayName 'Block legacy NAS SMB egress' -Direction Outbound -
RemoteAddress <nas_ip> -Protocol TCP -RemotePort 445 -Action Block
```

Fill in `<nas_ip>` before running it.

CONFIRM THE FIX

> The domain controllers still require signing, the legacy device reaches only the hosts it is allowed to, and a relay-target scan no longer includes any Tier 0 server.

Reports that message signing is enabled and required on the domain controller.

Linux shell

```
nmap -p445 --script smb2-security-mode <dc_ip>
```

Fill in `<dc_ip>` before running it.

CLOSES

ISO 27001:2022 A.8.20 A.8.21 A.8.22 DORA Art. 6 Art. 9(4)(b) ENS mp.com.3 mp.com.2 NIS2 Art. 21(2)(h) Art. 21(2)(e) PCI DSS 4.0 Req. 1 Req. 2 Req. 4 Req. 8 Req. 11 CIS WINDOWS SERVER 2.3.9.2 2.3.8.1 2.3.9.5

REFS

- https://attack.mitre.org/techniques/T1557/001/
- https://learn.microsoft.com/en-us/windows/security/threat-protection/security-policy-settings/microsoft-network-server-digitally-sign-communications-always

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

22 Weak Default Domain Password Policy

F-020 · MEDIUM · Priority 4 · DOMAIN CONFIGURATION · T1110.003 T1110.002

AFFECTED *domain-wide*

RUNBOOK

PRIMARY Harden the Default Domain Password Policy to the CIS / Microsoft baseline

STEPS

1. Edit the Default Domain Policy GPO (the DDPP is domain-wide; it cannot be set per-OU).
2. Raise minimum password length to >= 14, enable the complexity requirement, set password history to >= 24, and cap maximum password age (e.g. <= 365 days) per the recommended targets shown in the Observed vs Recommended table.
3. Set the account lockout threshold to a low value (e.g. 5) with a 15-minute observation window and duration.
4. Ensure 'Store passwords using reversible encryption' stays Disabled.
5. Force replication / gpupdate and confirm the new policy is in effect before communicating the change to users.

COMMANDS

In Group Policy, open Default Domain Policy > Computer Configuration > Policies > Windows Settings > Security Settings > Account Policies > Password Policy / Account Lockout Policy.

Apply via PowerShell (Default Domain Policy = the domain root policy).

PowerShell

```
Set-ADDefaultDomainPasswordPolicy -Identity north.sevenkingdoms.local -MinPasswordLength 14 -
ComplexityEnabled $true -PasswordHistoryCount 24 -MaxPasswordAge 365.00:00:00 -
LockoutThreshold 5 -LockoutObservationWindow 00:15:00 -LockoutDuration 00:15:00 -
ReversibleEncryptionEnabled $false
gpupdate /force
```

CONFIRM THE FIX

> The domain policy shows the target length, complexity, history and lockout values, and member hosts report the same thresholds.

MinPasswordLength, ComplexityEnabled, PasswordHistoryCount and LockoutThreshold match the targets.

PowerShell

```
Get-ADDefaultDomainPasswordPolicy
```

On a member host, the thresholds match.

PowerShell

```
net accounts
```


SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

FALLBACK

Layer a Fine-Grained Password Policy (PSO) for groups that need a stricter or different policy

When: If a domain-wide change risks breaking service accounts or legacy integrations, or Tier-0 admins need a stricter policy than the rest of the domain

STEPS

1. Create a Fine-Grained Password Policy (PSO) with the stricter targets (e.g. minimum length 20, shorter max age).
2. Apply the PSO to a security group (PSOs attach to groups/users, not OUs): e.g. a Tier-0 admins group, or conversely a tightly-scoped exception group for the accounts that genuinely cannot meet the domain default yet.
3. Confirm precedence: a lower 'Precedence' number wins when multiple PSOs apply to a user.
4. Plan to converge legacy exceptions back onto the hardened DDPP over time.

COMMANDS

PowerShell

```
New-ADFineGrainedPasswordPolicy -Name '<pso_name>' -Precedence 10 -MinPasswordLength 20 -
ComplexityEnabled $true -PasswordHistoryCount 24 -MaxPasswordAge 90.00:00:00 -LockoutThreshold
5 -LockoutObservationWindow 00:15:00 -LockoutDuration 00:15:00
Add-ADFineGrainedPasswordPolicySubject -Identity '<pso_name>' -Subjects '<tier0_admins_group>'
```

Fill in `<pso_name>` and `<tier0_admins_group>` before running it.

CONFIRM THE FIX

> Members of the target group receive the fine-grained policy, with its stricter settings, instead of the domain policy.

Returns the fine-grained policy, not the domain policy.

PowerShell

```
Get-ADUserResultantPasswordPolicy -Identity <privileged_account>
```

Fill in `<privileged_account>` before running it.

CLOSES

ISO 27001:2022 `A.5.17` `A.8.5` DORA `Art. 6` `Art. 9(4)(d)` ENS `op.acc.5`

NIS2 `Art. 21(2)(j)` `Art. 21(2)(i)` PCI DSS 4.0 `Req. 8` `Req. 12`

CIS WINDOWS SERVER `1.1.4` `1.1.5` `1.2.2`

REFS

- https://www.cisecurity.org/benchmark/microsoft_windows_server
- https://learn.microsoft.com/en-us/windows-server/identity/ad-ds/plan/security-best-practices/best-practices-for-securing-active-directory
- https://pages.nist.gov/800-63-3/sp800-63b.html
- https://attack.mitre.org/techniques/T1110/003/
- https://attack.mitre.org/techniques/T1110/002/

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

Identity & asset hygiene sweep

1 LOWER-SEVERITY ITEM · FIX AS A SINGLE SWEEP AFTER THE RUNBOOKS ABOVE

FINDING	AFFECTED	FIRST ACTION	SEVERITY
Machine Account Quota Allows Domain Join F-023	domain-wide	Set ms-DS-MachineAccountQuota to 0 with the ActiveDirectory module: Set-ADDomain -Identity north.sevenkingdoms.local -Replace @{'ms-DS-MachineAccountQuota'='0'}.	● LOW

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

Four weeks. *Remediation order first.* Re-scan on day 30.

W1 Break the validated attack paths first. These are the fixes ADscan proved reduce exposure most.

DAY 1–7

Path-breaker 1 of 3 ● HIGH **Kerberoasting**

sql_svc

Where possible, migrate the SPN to a Group Managed Service Account (gMSA), whose machine-managed password rotates automatically and resists offline cracking (see the detailed runbook)

OWNER / DONE

Path-breaker 2 of 3 ● HIGH **Constrained Kerberos Delegation Misconfiguration**

castelblack.north.sevenkingdoms.local (192.168.180.22)

Audit msDS-AllowedToDelegateTo attributes and remove any delegations to sensitive services such as CIFS, LDAP, or HOST on Domain Controllers

OWNER / DONE

Path-breaker 3 of 3 ● MEDIUM **AS-REP Roasting**

brandon.stark

Re-enable Kerberos pre-authentication on the affected account: clear the DONT_REQ_PREAUTH flag with Set-ADAccountControl -Identity brandon.stark -DoesNotRequirePreAuth $false (see the detailed runbook)

OWNER / DONE

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

W2 Close the remaining critical and high findings.

DAY 8–14

CRITICAL **Privileged Sessions on Lower-Tier Hosts**

Enforce the ESAE tiered-admin model: a Tier 0 account authenticates only to Tier 0 assets (Domain Controllers, PKI), and a Tier 1 server admin only to Tier 1 servers. A privileged account must never sign in to a host of lower trust

robb.stark signed in to castelblack.north.sevenkingdoms.local (192.168.180.22)

OWNER / DONE

CRITICAL **Account Passwords Recovered in This Assessment**

Reset the password of every account named here, starting with any administrative account, and treat each one as compromised until the reset is confirmed.

robb.stark

OWNER / DONE

HIGH **LDAP Signing / Channel Binding Not Hardened**

Enable LDAP signing requirement on all Domain Controllers

winterfell.north.sevenkingdoms.local (192.168.180.11)

OWNER / DONE

HIGH **LSASS Not Running as a Protected Process (RunAsPPL Disabled)**

Enable 'Configure LSASS to run as a protected process' via GPO, or set HKLM\SYSTEM\CurrentControlSet\Control\Lsa\RunAsPPL to 1.

winterfell.north.sevenkingdoms.local (192.168.180.11)

OWNER / DONE

HIGH **Credentials Stored in Directory Account Attributes**

Read each flagged attribute and clear the ones holding a secret.

samwell.tarly · description

OWNER / DONE

HIGH **noPac/sAMAccountName Spoofing (CVE-2021-42278 + CVE-2021-42287)**

Apply November 2021 Patch Tuesday updates on all Domain Controllers: KB5008380 (for all supported Windows Server versions) and KB5008602 (DC-specific security fix): both patches are required to fully close the attack chain

winterfell.north.sevenkingdoms.local (192.168.180.11)

OWNER / DONE

HIGH **PrintNightmare (CVE-2021-34527) Exposure in the Print Spooler**

Apply Microsoft security updates for CVE-2021-34527 on all affected hosts

winterfell.north.sevenkingdoms.local (192.168.180.11)

OWNER / DONE

HIGH **Child Domain Can Escalate to Forest Root (Intra-Forest Trust)**

Treat every domain in the forest as one Tier-0 security boundary: administer, monitor, and restrict each child domain to the same standard as the forest root, because a child-domain compromise is a forest compromise

sevenkingdoms.local

OWNER / DONE

HIGH **Sensitive Data Found in SMB Shares**

Immediately rotate all exposed credentials identified during the assessment

jeor.mormont

OWNER / DONE

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

W3 Clean up permissions and ACLs, harden the remaining protocols, and clear the hygiene backlog.

DAY 15–21

MEDIUM Accounts with Non-Expiring Passwords

Review all accounts with DONT_EXPIRE_PASSWORD set and determine whether the business justification remains valid

Administrator

OWNER / DONE

MEDIUM Passwords Predating Current Policy

Identify all accounts whose pwdLastSet predates the policy's last modification

Administrator

OWNER / DONE

MEDIUM Kerberos Web Service (HTTP SPN) Relay and Coercion Surface

Inventory every HTTP SPN in the domain and confirm each one maps to a documented, still-needed web service; remove SPNs left behind by decommissioned applications with setspn

castelblack.north.sevenkingdoms.local (192.168.180.22) · HTTP/winterfell.north.sevenkingdoms.local

OWNER / DONE

MEDIUM Domain Does Not Force AES Encryption for Kerberos

Set msDS-SupportedEncryptionTypes on the domain object to 24 (AES128 + AES256 only)

OWNER / DONE

MEDIUM Domain Controller Accepts RC4 Kerberos Encryption

Set 'Network security: Configure encryption types allowed for Kerberos' to AES128 + AES256 only via GPO

winterfell.north.sevenkingdoms.local (192.168.180.11)

OWNER / DONE

MEDIUM krbtgt Account Password Not Rotated

Rotate the krbtgt password twice (with a replication interval between rotations) at least every 180 days.

krbtgt

OWNER / DONE

MEDIUM Domain Controller Accepts NTLM Authentication

Audit NTLM usage via DC event log 8001-8004 to identify dependent applications and clients

winterfell.north.sevenkingdoms.local (192.168.180.11)

OWNER / DONE

MEDIUM SMB Null Session Authentication on DC

Remove the membership of the “Anonymous Logon” group from the “Pre-Windows 2000 Compatible Access” group

OWNER / DONE

MEDIUM SMB Signing Not Required

Set 'Microsoft network server: Digitally sign communications (always)' via GPO

castelblack.north.sevenkingdoms.local (192.168.180.22)

OWNER / DONE

MEDIUM Weak Default Domain Password Policy

Enforce account lockout threshold ≥ 5 attempts with a reasonable observation window (CIS: 5 attempts / 15-minute window / 15-minute duration).

OWNER / DONE

LOW Machine Account Quota Allows Domain Join

Set ms-DS-MachineAccountQuota to 0 with the ActiveDirectory module: Set-ADDomain -Identity north.sevenkingdoms.local -Replace @{'ms-DS-MachineAccountQuota'='0'}.

OWNER / DONE

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

W4 Re-baseline, validate, and lock a recurring cadence.

DAY 22–30

INFO **Re-scan and confirm closure**

Re-run ADscan against every domain in scope; confirm each finding above is closed or compensated and capture the new posture delta.

OWNER / DONE

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

What an auditor will *flag* first.

Every confirmed finding maps to one or more framework controls. Closing the roadmap above closes these gaps; until then they are open audit items.

ISO 27001:2022

12 controls · 23 findings

A.5.17 A.5.18 A.8.18 A.8.2 A.8.20 A.8.21 A.8.22 A.8.24 A.8.3 A.8.5 A.8.8 A.8.9

DORA

8 controls · 23 findings

Art. 6 Art. 8 Art. 9(2) Art. 9(3) Art. 9(4)(b) Art. 9(4)(c) Art. 9(4)(d) Art. 9(4)(f)

ENS

11 controls · 23 findings

mp.com.2 mp.com.3 op.acc.2 op.acc.3 op.acc.4 op.acc.5 op.acc.6 op.exp.10 op.exp.2 op.exp.4 org.4

NIS2

4 controls · 23 findings

Art. 21(2)(e) Art. 21(2)(h) Art. 21(2)(i) Art. 21(2)(j)

PCI DSS 4.0

9 controls · 23 findings

Req. 1 Req. 11 Req. 12 Req. 2 Req. 3 Req. 4 Req. 6 Req. 7 Req. 8

CIS Windows Server

29 controls · 22 findings

1.1.1 1.1.2 1.1.4 1.1.5 1.2.2 18.7.1 18.9.26.2 2.2.2 2.2.28 2.2.48 2.3.10.1 2.3.10.10 2.3.10.11 2.3.10.12 2.3.10.2 2.3.10.5 2.3.11.10 2.3.11.11 2.3.11.4 2.3.11.7 2.3.11.9 2.3.5.3 2.3.5.4 2.3.5.5 2.3.6.5 2.3.8.1 2.3.9.2 2.3.9.5 5.1

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

Six tactics behind *most* confirmed AD breaches.

Every finding above maps to one of these six tactics. The chapters ADscan observed in your scan are marked with a count; the rest stay as general-hardening reference so your team can close the gap before it becomes a finding.

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

OBSERVED · 4

Audit the ACLs that audit nothing.

WHAT ATTACKERS DO

- → Abuse GenericAll / GenericWrite on user or group objects for takeover (T1098).
- → Escalate via WriteOwner or WriteDACL to chain into DCSync rights (T1068).
- → Hijack a Valid Account via ForceChangePassword to pivot into Tier 0 (T1078, T1078.002).
- → Compromise a domain-joined service account to reach Domain Admin (T1078.003).
- → Chain Backup Operators or Server Operators to local SYSTEM on a DC.

WHAT DEFENDERS DO

- ✓ Review every non-default ACE on Domain Admins, EAs, and AdminSDHolder.
- ✓ Remove AuthenticatedUsers / Domain Users write entries on privileged objects.
- ✓ Tier sensitive groups: deny membership change except via PAW workflow.
- ✓ Alert on ACL writes to AdminSDHolder, krbtgt, and DC computer objects.
- ✓ Empty Account / Backup / Server Operators unless actively used and audited.

30-DAY PRIORITY	EFFORT	IMPACT
Day 1-7	L	Critical

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

OBSERVED · 3

Stop trading tickets for tokens.

WHAT ATTACKERS DO

- → Kerberoast SPN-bearing accounts (T1558.003) for offline cracking.
- → AS-REP roast accounts with pre-auth disabled (T1558.004).
- → Dump LSASS for cached credentials and TGTs (T1003.001); steal DPAPI secrets from Password Stores (T1555).
- → DCSync replicate from a compromised user with DS-Replication rights (T1003.006).
- → Steal NTDS.dit through shadow copy or backup operator abuse (T1003.003); forge Authentication Certificates via ADCS (T1649).

WHAT DEFENDERS DO

- ✓ Reset every SPN account password to 30+ char random; rotate quarterly.
- ✓ Enable Kerberos pre-auth on every human account; alert on disablement.
- ✓ Enforce LSASS protected process light (RunAsPPL) and Credential Guard.
- ✓ Restrict Replicate Directory Changes to a named, audited set of accounts.
- ✓ Move NTDS.dit backups out of band; alert on shadow copy creation by non-DCs.

30-DAY PRIORITY

Day 1-7 / 8-14

Roasting and pre-auth hardening land in week 1; LSASS protection (RunAsPPL, Credential Guard) and the DCSync rights review span week 2.

EFFORT

M

IMPACT

Critical

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

OBSERVED · 2

Make every hop expensive.

WHAT ATTACKERS DO

- → Pass-the-Hash with cached NTLM secrets across SMB admin shares (T1550.002, T1021.002).
- → Pass-the-Ticket with stolen Kerberos TGTs to impersonate users (T1550.003).
- → Resource-Based Constrained Delegation abuse via writable computer object.
- → Overpass-the-Hash to upgrade an NTLM hash into a usable Kerberos TGT.
- → Lateral RDP / WinRM after dumping cached credentials (T1021.001).
- → Exploit unpatched services reachable inside the domain (T1210, PrintNightmare, MS17-010).

WHAT DEFENDERS DO

- ✓ Enable SMB signing on every host; require it on the DC.
- ✓ Add Tier 0 admins to Protected Users and the local Deny Logon GPO.
- ✓ Set ms-DS-MachineAccountQuota to 0 to kill RBCD via new computer accounts.
- ✓ Disable WDigest, enable LSA Protection, deploy Credential Guard fleet-wide.
- ✓ Restrict NTLM at the domain level (Audit then Deny) once telemetry is clean.

30-DAY PRIORITY	EFFORT	IMPACT
Day 8-14	L	Critical

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

OBSERVED · 2

Win the first 30 seconds of the engagement.

WHAT ATTACKERS DO

- → Poison LLMNR / NBT-NS / mDNS to capture broadcast hashes (T1557.001).
- → Coerce SMB / WebDAV authentication via PetitPotam or PrinterBug.
- → Password-spray valid usernames harvested from OSINT (T1110.003).
- → AS-REP roast every domain account to find pre-auth-disabled users.
- → Relay coerced NTLM auth into LDAP or ADCS for credential or cert theft.

WHAT DEFENDERS DO

- ✓ Disable LLMNR and NBT-NS via GPO across every workstation OU.
- ✓ Patch Print Spooler abuse paths; disable spooler on every DC.
- ✓ Enforce a domain lockout policy: 5 attempts, 15 min, observable threshold.
- ✓ Audit every account for pre-auth disabled; re-enable or document exception.
- ✓ Enable EPA on ADCS web enrollment and HTTPS-only LDAP on every DC.

30-DAY PRIORITY

Day 1-7 / 15-28

The coercion-to-relay-to-ADCS chain is a week-1 path-breaker; poisoning, spraying and lockout hardening land in weeks 3 to 4.

EFFORT

S

IMPACT

High

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

Close the back doors before they re-open.

WHAT ATTACKERS DO

- → Forge a Golden Ticket using krbtgt secrets after DCSync.
- → Plant a Skeleton Key or DSRM admin reuse for offline domain re-entry.
- → Add SIDHistory pointing at Enterprise Admins for a hidden privilege bridge.
- → Drop a DCShadow rogue replication source to hide future changes.
- → Modify AdminSDHolder to make persistence stick across SDProp.

WHAT DEFENDERS DO

- ✓ Rotate krbtgt twice with a 24h gap immediately after any DCSync incident.
- ✓ Disable DSRM admin network logon; rotate the DSRM password quarterly.
- ✓ Audit SIDHistory across every account; clear unjustified entries.
- ✓ Alert on DRS-Mod rights grants and on AdminSDHolder DACL changes.
- ✓ Forward DC security logs to an out-of-domain SIEM with retention >90d.

SCHEDULING

General hardening · not scheduled

EFFORT

M

IMPACT

Critical

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

Take RC4 and NTLM off the table.

WHAT ATTACKERS DO

- → Downgrade Kerberos to RC4 to make kerberoast hashes crackable in hours.
- → Force NTLMv1 via LLMNR/NBT-NS/mDNS poisoning to relay or crack offline.
- → Relay any NTLM authentication (v1 or v2) to LDAP or ADCS when signing is absent.
- → Sniff cleartext LDAP traffic on TCP/389 when LDAPS is not deployed (DCs lacking a TLS cert).
- → Disable SMB signing per-share to enable relay against admin sessions.
- → Mint silver tickets against weakly encrypted services post-roast.
- → Tamper with audit policy to strip ticket and logon telemetry (T1070).

WHAT DEFENDERS DO

- ✓ Set msDS-SupportedEncryptionTypes to AES-only on every privileged account, then commit AES-only at the domain level (close the RC4 negotiation downgrade path).
- ✓ Deploy a Server Authentication cert on every Domain Controller so LDAPS works on TCP/636: this is a prerequisite for LDAP channel binding.
- ✓ Drive a two-phase NTLM reduction: (1) disable NTLMv1 immediately; (2) restrict NTLM domain-wide after a 30-90d audit window using DC event 8001-8004.
- ✓ Enforce SMB signing required on servers and Always Encrypt LDAP.
- ✓ Require LDAP channel binding and signing on every DC (depends on LDAPS being available first).
- ✓ Do not treat StartTLS on TCP/389 as a substitute for enforcing signing and channel binding: StartTLS only encrypts the transport, it does not force authenticated integrity. Deploy LDAPS and enforce both signing and channel binding on every DC.
- ✓ Lock audit policy via GPO; forward Sysmon + 4624/4625/4769 to SIEM.

SCHEDULING	EFFORT	IMPACT
General hardening · not scheduled	M	High

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

Hardening is a *habit you keep*.

> ***Close the 11 critical and high findings this month and you break the most common kill chain in your environment. Re-scan on day 30 to prove it.***

SHIP FIRST

11

critical and high findings that lead the 30-day roadmap by severity.

WEEK 1 WORKLOAD

3

actions scheduled for days 1–7, each with its owner and its verification step.

RE-BASELINE

Day 30

Re-run the assessment and compare against the 23 findings recorded here. That comparison is what proves the work landed.

BEFORE YOU CHANGE ANYTHING

Freeze the baseline

Keep this document and its finding IDs. Every claim you make on day 30 is measured against them.

AS EACH ACTION LANDS

Run its verification

Each remediation in this playbook ends with the command that proves the fix took. Record the output beside the finding ID.

ON DAY 30

Re-assess and compare

A finding that no longer appears is closed. One that persists needs the fallback route documented with it.

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.